

Faculty of Informatics Engineering
Department of Systems Security
and Computer Networking



Cloud IAM Analyzer with Honeypot

Prepared by:

Gabriella Haddad
Elyana Koryakos
Khalid Alnabulsi

Supervised by:

**Dr. Christine Zenieh
Eng. Mouhamad Amjad Al Safadi**

2025/2026

SUPERVISOR CERTIFICATION

I certify that the preparation of this project entitled **Cloud IAM Analyzer with Honeypot**, prepared by Gabriella Haddad, and Elyana Koryakos, and Khalid Alnabulsi, was made under my supervision at Faculty of Computer, Informatics & Communication Engineering in partial fulfillment of the Requirements for the Degree of Bachelors of Systems Security & Computers Networks Engineering.

Name:

Signature:

Date:

الملخص

شهد أمن المعلومات السحابية في السنوات الأخيرة اهتماماً متزايداً لدى المؤسسات، في ظل الانتقال المتسارع من البنى التحتية التقليدية إلى البيئات السحابية. ورغم ما توقعه هذه البيئات من مزايا تتعلق بالمرونة، وقابلية التوسع، والكفاءة التشغيلية، فإن تعقيدها المتزايد أظهر تحديات أمنية جديدة، ومن أبرز هذه التحديات إدارة الهوية والصلاحيات.

تمثل إدارة الهوية والصلاحيات (Identity and Access Management – IAM) الأساس الذي تُبنى عليه آليات التحكم بالوصول إلى الموارد السحابية. ومع توسع البيئات السحابية وتعدد مكوناتها، تتزايد درجة التعقيد في علاقات الصلاحيات بين المستخدمين، والأدوار، والسياسات الأمنية، نتيجة التغيرات المستمرة في الهياكل التنظيمية والوظيفية، ويؤدي هذا التعقيد في كثير من الحالات إلى ظهور أخطاء في تهيئة سياسات IAM أو إلى تراكم غير مقصود للصلاحيات، وهي مشكلات قد لا يتم اكتشافها بالاعتماد على المراجعة التقليدية لإعدادات الوصول فقط.

يهدف هذا المشروع إلى تطوير وتنفيذ إطار تحليلي لتحليل أنظمة إدارة الهوية والصلاحيات في البيئات السحابية، من خلال تنظيم مكونات IAM ودراسة العلاقات بين المستخدمين والأدوار والصلاحيات، إضافة إلى تحليل السياسات الأمنية اعتماداً على منهجية التحليل الساكن. يتضمن المشروع بناء أداة تحليل تقوم باستخراج سياسات IAM من بيئة سحابية تجريبية، ثم تحليلها ساكناً للكشف عن أخطاء الضبط مثل منح صلاحيات واسعة ضمن نطاق غير مناسب أو تراكم الصلاحيات عبر العضويات والمجموعات.

كما يناقش المشروع مفهوم المصائد الأمنية (Honeypots) ودمجها ضمن البيئة التجريبية كطبقة رصد سلوكي، بهدف مراقبة التفاعلات المشبوهة ومحاولات الوصول غير المصرح بها، وربط سلوك التهديدات المحتملة بنقاط الضعف المرتبطة بتهيئة سياسات الوصول وتوزيع الصلاحيات.

الفهرس

10	1 الفصل الأول - الدراسة النظرية
10	1.1 الحوسبة السحابية (Cloud Computing)
10	1.1.1 تعريف الحوسبة السحابية
10	1.1.2 نماذج النشر في السحابة (Cloud Deployment Models)
11	1.1.3 نماذج الخدمة في السحابة (Cloud Service Models)
11	1.1.4 خصائص الحوسبة السحابية (Cloud Characteristics)
12	1.1.5 أمن السحابة (Cloud Security)
12	1.1.6 التحديات الأمنية في الحوسبة السحابية (Cloud Security Challenges)
13	1.1.7 العلاقة بين الحوسبة السحابية وإدارة الهوية والصلاحيات
13	1.2 إدارة الهوية والصلاحيات IAM
13	1.2.1 تعريف IAM ودوره في أمن السحابة
13	1.2.2 مكونات IAM الأساسية
14	1.2.3 آليات التحقق من الهوية (Authentication)
16	1.2.4 آليات التفويض ونماذج التحكم بالوصول (Authorization)
17	1.2.5 تهيئة أنظمة IAM (IAM Configuration)
17	1.2.6 أخطاء إعداد IAM (IAM Misconfigurations)
18	1.2.7 تأثير سوء إعداد IAM على الأمن السحابي
19	1.2.8 أهمية تحليل أنظمة IAM في البيئات السحابية
19	1.2.9 دور IAM في تعزيز أمن السحابة
20	1.2.10 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات (Future Trends in IAM)
21	1.3 أدوات تحليل IAM السحابية (IAM Analysis Tools)
21	1.4 سياسات إدارة الهوية والصلاحيات (IAM Policies)

22	1.5 المصائد الأمنية (Honeypots).....
22	1.5.1 تعريف المصائد الأمنية.....
22	1.5.2 أنواع المصائد الأمنية.....
23	1.5.3 دور المصائد الأمنية في البيئات السحابية.....
23	1.5.4 التحديات والمخاطر المرتبطة باستخدام Honeypots
23	1.5.5 المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots)
24	1.6 تصنيف المستخدمين (User Classification).....
24	1.6.1 تعريف المستخدم الشرعي (Legitimate User)
24	1.6.2 تعريف المهاجم (Attacker)
25	1.7 السجلات (Logs).....
25	1.7.1 تعريف السجلات.....
25	1.7.2 نظام تسجيل السجلات (Log Recording Systems)
25	1.7.3 مكونات نظام تسجيل السجلات
25	1.7.4 آلية تبادل السجلات (Log Transmission Mechanism)
28	2 الفصل الثاني - الدراسات السابقة.....
28	2.1 الدراسات السابقة.....
31	2.2 مقارنة بين المشروع والدراسات السابقة.....
35	3 الفصل الثالث - الحل المقترح.....
36	3.1 بيئة العمل السحابية.....
36	3.1.1 منصة Openstack.....
37	3.1.2 منصة MicroStack.....
38	3.1.3 الفرق بين OpenStack وMicrostack.....
38	3.2 أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)

38	3.2.1 مرحلة التجميع (Collection Phase)
40	3.2.2 مرحلة التهيئة والمعالجة المبدئية (Normalization Phase)
42	3.2.3 مرحلة بناء الرسم البياني (Graph Construction Phase)
45	3.2.4 مرحلة القواعد الساكنة (Static Rules Phase)
48	3.3 المصيدة الأمنية (HoneyPot)
48	3.3.1 تصميم بيئة المصيدة الأمنية ضمن MicroStack
48	3.3.2 إنشاء المصيدة الأمنية (HoneyPot Deployment)
49	3.3.3 تكامل المصيدة الأمنية مع أداة تحليل إدارة الهوية والصلاحيات
52	4 الفصل الرابع - النتائج
52	4.1 بنية مخرجات الأداة (Alert Structure)
53	4.2 السيناريو التجريبي المعتمد
54	4.3 تنفيذ السيناريو
54	4.4 النتائج المكتشفة بواسطة القواعد الساكنة
55	4.4.1 الصلاحيات المفرطة (T1 – Excessive Privilege)
55	4.4.2 الضعف الدلالي في سياسات التفويض (T4 – Policy Semantic Weakness)
55	4.4.3 تعريض الواجهات الإدارية (T9 – Admin Surface Exposure)
55	4.4.4 الوصول إلى عمليات حساسة (X1 / X2)
56	4.4.5 تفسير النتائج وحدود التحليل
56	4.4.6 النتائج الإيجابية الكاذبة (False Positives)
58	الخاتمة
59	المراجع

المقدمة

شهد العقد الأخير تحولاً جذرياً في أساليب تصميم وتشغيل البنى التحتية لتكنولوجيا المعلومات، حيث أصبحت الحوسبة السحابية أحد الركائز الأساسية للتحول الرقمي على المستوى العالمي، لما توفره من مرونة تشغيلية، وقابلية عالية للتوسع، وكفاءة في إدارة الموارد، مما جعلها خياراً استراتيجياً للعديد من المؤسسات بمختلف أحجامها وقطاعاتها.

في هذا الإطار، برزت المنصات السحابية المفتوحة كمكوّن أساسي في بناء البيئات السحابية الحديثة، لما توفره من مرونة والاستقلالية عن مزود الخدمات المغلقة. ويُعد OpenStack من أبرز هذه المنصات، إذ يتيح إنشاء بنى سحابية موزّعة قابلة للتكيف مع متطلبات التشغيل المختلفة. واعتماداً على ذلك، تم استخدام MicroStack بوصفه نسخة مبسّطة من OpenStack، توفر بيئة مناسبة للمحاكاة والتجريب، وتمكّن من تمثيل المكونات السحابية ودراسة آليات عملها على المستويين التشغيلي والأمني.

غير أن هذا التحول نحو البيئات السحابية الموزّعة رافقه تغيير جوهري في نماذج الحماية الأمنية. فلم تعد الآليات التقليدية القائمة على حدود الشبكة الثابتة كافية لضمان أمن الأنظمة، وذلك نتيجة طبيعة السحابة التي تعتمد على موارد موزّعة، وتدعم الوصول عن بُعد، وتسمح بتفاعل عدد كبير من المستخدمين والكيانات عبر طبقات مختلفة من الخدمات. وقد أدّى ذلك إلى بروز تحديات أمنية جديدة، خاصة فيما يتعلق بالتحكم بالوصول إلى الموارد الرقمية الحساسة.

في هذا السياق، أصبحت إدارة الهوية والصلاحيات (Identity and Access Management – IAM) الركيزة الأساسية لضبط الوصول في البيئات السحابية، حيث تعتمد هذه البيئات بشكل محوري على الهوية الرقمية في تحديد الصلاحيات والامتيازات الممنوحة للمستخدمين والكيانات المختلفة. إلا أن التعقيد المتزايد في سياسات الوصول، وتنوّع الأدوار، وتغيّر الهياكل التنظيمية، يؤدّي في كثير من الحالات إلى أخطاء في تهيئة أنظمة IAM أو إلى تراكم غير مقصود للصلاحيات، وهو ما قد يفتح المجال لثغرات أمنية يصعب اكتشافها بالاعتماد على الأساليب اليدوية أو المراجعات التقليدية.

وانطلاقاً من ذلك، ركّز هذا المشروع على تحليل أنظمة إدارة الهوية والصلاحيات في البيئات السحابية ضمن إطار منهجي يجمع بين دراسة بنية الصلاحيات وتحليل العلاقات بين المستخدمين والأدوار وسياسات الوصول. ويعتمد الجانب العملي من المشروع على تصميم وتنفيذ إطار تحليلي لتقييم تهيئة أنظمة IAM في بيئة سحابية تجريبية مبنية على OpenStack، من خلال جمع بيانات الهوية والصلاحيات، وتحليل الترابط بينها، وتمثيل هذه العلاقات بشكل منظمّ يتيح الكشف عن تداخل الصلاحيات وتراكُمها.

ويقتصر نطاق هذا العمل على دراسة الجوانب المرتبطة بإدارة الهوية والصلاحيات دون التوسّع في بقية عناصر أمن السحابة، مع التركيز على مشكلات الضبط غير الأمن من منظور تحليلي منهجي. ويسعى المشروع إلى تقديم فهم أعمق لبنية أنظمة IAM والمخاطر المرتبطة بها، بما يشكّل أساساً يمكن البناء عليه في دراسات ومشاريع لاحقة ضمن مجال أمن الحوسبة السحابية.

الفصل الأول

الدراسة النظرية

1 الفصل الأول - الدراسة النظرية

يستعرض هذا الفصل المفاهيم النظرية الأساسية التي يستند إليها هذا المشروع، بدءاً من الحوسبة السحابية ونماذجها المختلفة، مروراً بأمن السحابة وأنظمة إدارة الهوية والصلاحيات (IAM)، وصولاً إلى تقنيات المصادد الأمنية وأدوات تحليل أنظمة IAM. يهدف هذا الفصل إلى بناء إطار معرفي نظري يوضح الأسس المفاهيمية المرتبطة بإدارة الوصول وأمن الهوية في البيئات السحابية.

1.1 الحوسبة السحابية (Cloud Computing)

الحوسبة هي عملية معالجة البيانات باستخدام أجهزة الكمبيوتر لتنفيذ مهام محددة، سواء كانت حسابية أو منطقية أو غيرها. تشمل الحوسبة تصميم وبناء أنظمة الكمبيوتر، وتطوير البرمجيات، وتحليل البيانات، والذكاء الاصطناعي، والعديد من التطبيقات الأخرى.

1.1.1 تعريف الحوسبة السحابية [1]

نمط من أنماط الحوسبة حيث تتيح للمستخدم الوصول التلقائي حسب الطلب إلى موارد حاسوبية افتراضية (مثل الشبكات، الخوادم، التخزين، التطبيقات، والخدمات) من دون الحاجة إلى شراء أو إدارة هذه الموارد مادياً. تعتمد هذه التقنية على مراكز بيانات ضخمة يتم التحكم بها مركزياً، وتُدار بكفاءة عالية لضمان استمرارية الخدمة. تُعد الحوسبة السحابية ثورة في مجال تكنولوجيا المعلومات، كونها توفر المرونة، التوسع حسب الطلب، وخفض التكاليف التشغيلية للمؤسسات.

1.1.2 نماذج النشر في السحابة (Cloud Deployment Models) [2]

تعتمد بيئات الحوسبة السحابية على ثلاثة نماذج نشر رئيسية تُختار وفقاً لمتطلبات الأمان، الخصوصية، الحوكمة، والأداء:

- السحابة العامة (Public Cloud): يملكها ويشغلها مزود خدمات خارجي، وتُتاح عبر الإنترنت لعامة المستخدمين ويتميز بالتكلفة المنخفضة والمرونة العالية بسعر الاستخدام حسب الطلب.
 - السحابة الخاصة (Private Cloud): تُنشأ وتُدار داخلياً داخل مؤسسة واحدة، سواء في مركز بيانات خاص أو من قبل مزود مؤمن.
 - السحابة الهجينة (Hybrid Cloud): تدمج بين السحابة العامة والخاصة، ما يتيح نقل البيانات والتطبيقات بين النماذج حسب الحاجة.
- الاختيار بين هذه النماذج يعتمد على مستوى الخصوصية والحساسية المطلوبة، التكلفة، الحوكمة، وقدرة المنظمة على إدارة البنية التحتية التقنية، وفي إطار هذا العمل تم اعتماد نموذج السحابة الخاصة (Private Cloud) لأن البيئة المستخدمة في المشروع تُدار بشكل كامل داخلياً، مع تحكّم كامل بالبنية التحتية وسياسات إدارة الهوية والصلاحيات.

1.1.3 نماذج الخدمة في السحابة (Cloud Service Models) [1]

تنقسم الحوسبة السحابية إلى ثلاث طبقات لتقديم الخدمة، تختلف كل منها في مستوى التحكم الإداري وموارد البنية التحتية التي يتحكم بها المستخدم:

- SaaS – البرمجيات كخدمة (Software as a Service): توفر الوصول إلى تطبيقات جاهزة تعمل عبر الإنترنت دون الحاجة لأي إدارة للبنية التحتية أو نظام التشغيل بحيث يقتصر دور المستخدم على إعدادات التطبيق فقط، بينما يتحمل المزود مسؤولية تشغيل الخادم، التخزين، الشبكة والتحديثات.
 - PaaS – المنصة كخدمة (Platform as a Service): تقدم بيئة متكاملة لتطوير التطبيقات ونشرها، تشمل نظام تشغيل، قواعد بيانات، خوادم تطبيقات وأطر عمل، مما يتيح للمطورين التركيز على البرمجيات بينما يدير المزود البنية التحتية.
 - IaaS – البنية التحتية كخدمة (Infrastructure as a Service): توفر موارد حاسوبية أساسية مثل الخوادم الافتراضية، التخزين، والشبكات للتحكم الكامل من قبل المستخدم، الذي يدير نظام التشغيل والتطبيقات. البنية التحتية الفعلية والافتراضية تُدار من قبل المزود، ويحاسب المستخدم حسب الاستخدام.
- تُوفر هذه النماذج مستويات مختلفة من الإدارة والمرونة وتُستخدم بحسب احتياجات المؤسسة، وضمن إطار هذا المشروع، يتم التركيز بشكل رئيسي على نموذج البنية التحتية كخدمة (Infrastructure as a Service – IaaS)، نظراً لاعتماده المكثف على آليات إدارة الهوية والصلاحيات في التحكم بالوصول إلى الموارد السحابية مثل الخوادم الافتراضية، الشبكات، والتخزين.

1.1.4 خصائص الحوسبة السحابية (Cloud Characteristics) [1]

تُعرف الحوسبة السحابية بخمسة خصائص تقنية أساسية تجعلها خياراً استراتيجياً لتشغيل الأنظمة الرقمية.

من أهم هذه الخصائص:

- الوصول الفوري عند الطلب (On-Demand Self-Service): يمكن للمستخدم طلب موارد دون تدخل بشري.
 - الوصول الواسع عبر الشبكة (Broad Network Access): يمكن الوصول إلى الخدمات من أي مكان.
 - تجميع الموارد (Resource Pooling): يتم تجميع الموارد لخدمة عدة عملاء وفقاً لمبدأ تعدد المستأجرين.
 - المرونة القابلة للتوسع (Rapid Elasticity): يمكن توسيع الموارد أو تقليصها ديناميكياً.
 - الخدمة المقاسة (Measured Service): يتم قياس استخدام الموارد وتُحسب الرسوم حسب الاستخدام الفعلي.
- تتيح هذه الخصائص توفير بيئة تشغيلية مرنة وآمنة ومتوافقة مع احتياجات المؤسسات الحديثة.

1.1.5 أمن السحابة (Cloud Security) [3]

أمن الحوسبة السحابية هو مجموعة من الضوابط التقنية والتنظيمية المصممة لحماية بيانات التشغيل السحابية من التهديدات المتقدمة ومخاطر فقدان البيانات.

يختلف أمن السحابة عن أمن البنى التقليدية نتيجة خصائصها مثل تعدد المستأجرين (Multi-tenancy) والاعتماد على الاتصال الواسع بالشبكة. ولهذا، يتطلب الأمر حلاً أمنياً مصمماً خصيصاً لخصائص السحابة.

تشمل الممارسات الأساسية لأمن السحابة ما يلي:

- التحكم في الهوية والوصول (IAM): اعتماد نموذج صارم لإدارة الهوية.
- تشفير البيانات (Data Encryption): حماية البيانات أثناء النقل وأثناء التخزين مع ضمان إدارة فعالة للمفاتيح.
- العزل الأمني (Tenant Isolation): وضع آليات عزل صارمة بين المستأجرين لضمان عدم تسرب البيانات بين العملاء المشتركين في البنية نفسها.
- الرصد المستمر (Continuous Monitoring): الاعتماد على أدوات تحليل سلوكي، وكشف التهديدات، وتسجيل الأنشطة (Log Auditing) لتحديد الأنماط غير الطبيعية والاستجابة للحوادث بسرعة.
- الدفاع متعدد الطبقات (Defense in Depth): توزيع الضوابط الأمنية عبر طبقات مختلفة (الشبكة، الأجهزة الافتراضية) لتوفير حماية متكاملة ومرنة.

1.1.6 التحديات الأمنية في الحوسبة السحابية (Cloud Security Challenges) [4]

رغم الميزات العديدة التي تقدمها الحوسبة السحابية، إلا أن هناك تحديات أمنية بارزة يجب الانتباه لها ومن أهم هذه التحديات:

- تنفيذ التكوينات غير الآمنة (Misconfiguration): يحدث هذا التحدي عندما يتم إعداد مكونات النظام السحابي (مثل التخزين، أو قواعد البيانات، أو إعدادات الشبكة) بشكل غير صحيح، مما يفتح ثغرات قد يستغلها المهاجمون للوصول غير المصرح به إلى البيانات أو الخدمات.
- تعدد المستأجرين: في بيئات الحوسبة السحابية، قد تشارك عدة كيانات أو مستخدمين نفس الموارد، مما يزيد من احتمالية حدوث أخطاء في تحديد الأذونات والصلاحيات، وبالتالي يزيد من خطر وصول المستخدمين إلى بيانات أو خدمات لا يُفترض بهم الوصول إليها.
- هجمات الشبكة مثل DDoS واعتراض البيانات: تعتبر هجمات حجب الخدمة (DDoS) من التهديدات الخطيرة في البيئة السحابية، إذ يستطيع المهاجم إرسال كميات هائلة من البيانات لتعطيل الخدمات السحابية. كما أن اعتراض البيانات أثناء نقلها بين المستخدمين والخدمات السحابية قد يؤدي إلى تسرب معلومات حساسة إذا لم يتم استخدام بروتوكولات التشفير المناسبة.

- إدارة المفاتيح المعقدة: تعتمد الخدمات السحابية على تشفير البيانات لضمان سريتها وإن إدارة مفاتيح التشفير بشكل غير صحيح يؤدي إلى فقدان الوصول إلى البيانات أو تسريب المفاتيح للمهاجمين، مما يعرض البيانات لخطر الانكشاف.
- هذه التحديات تتطلب اعتماد ضوابط صارمة، مثل التشفير الطرفي، مراجعة الصلاحيات، واستخدام تقنيات مراقبة متقدمة لضمان حماية البيئة السحابية بشكل فعال.

1.1.7 العلاقة بين الحوسبة السحابية وإدارة الهوية والصلاحيات

مع الاعتماد المتزايد على نماذج الحوسبة السحابية، ولا سيما البيئات القائمة على IaaS و PaaS، لم تعد آليات الحماية التقليدية القائمة على العزل الشبكي كافية لضمان أمن الموارد والخدمات. في هذا السياق، أصبحت الهوية الرقمية هي المحور الأساسي للتحكم بالوصول، حيث تعتمد معظم العمليات السحابية على التحقق من هوية المستخدم أو الخدمة قبل السماح بأي تفاعل مع الموارد. يشكل هذا التحول الأساس النظري لظهور أنظمة إدارة الهوية والصلاحيات كعنصر مركزي في أمن السحابة، إذ يتم من خلالها ضبط الوصول، تقليل الصلاحيات غير الضرورية، ومراقبة الأنشطة بشكل دقيق. كما تشير الدراسات الحديثة إلى أن فعالية أمن السحابة ترتبط بشكل مباشر بمدى نضج سياسات IAM وتكاملها مع آليات المراقبة والتحليل الأمني.

1.2 إدارة الهوية والصلاحيات IAM

تُعتبر إدارة الهوية والصلاحيات (IAM) جوهرًا في البنية الأمنية لأي نظام رقمي، وخصوصاً في بيئات الحوسبة السحابية، حيث يتنوع المستخدمون وتزداد نقاط الدخول والخروج من النظام.

1.2.1 تعريف IAM ودوره في أمن السحابة [5]

IAM هو إطار عمل يتضمن السياسات والتقنيات المستخدمة لتحديد هوية المستخدمين، والتحكم في صلاحياتهم، وإدارتها عبر أنظمة تقنية متعددة. في الحوسبة السحابية يعمل IAM كخط الدفاع الأول، حيث يضمن أن كل عملية وصول إلى المورد تخضع للتحقق والتفويض المناسبين. يشمل دور IAM في أمن السحابة:

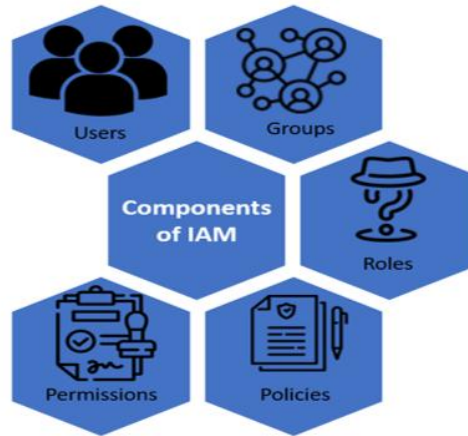
- التأكد من أن كل مستخدم أو خدمة يتم تعريفها والتحقق منها (Authentication).
- تحديد ما يُسمح لكل مستخدم بفعله (Authorization).
- تسجيل ومراجعة جميع الأنشطة لضمان الشفافية والتحقق في حال وقوع حوادث أمنية.

1.2.2 مكونات IAM الأساسية [8]

يتكوّن نظام IAM من مجموعة من العناصر الأساسية:

- Users (المستخدمون): يمثلون الأفراد أو الكيانات التي تطلب الوصول إلى موارد معينة.
- Roles (الأدوار): مجموعة من الصلاحيات تُمنح لمجموعة من المستخدمين.

- Policies (السياسات): قواعد مكتوبة تحدد ما يمكن وما لا يمكن للمستخدم أو الدور فعله.
 - Permissions (الأذونات): التصاريحات المحددة للوصول إلى مورد معين أو تنفيذ إجراء ما.
- يتم تنظيم هذه المكونات عبر واجهات متقدمة توفرها منصات مثل AWS IAM أو Azure Active Directory لضمان الدقة والقابلية للإدارة في بيئة معقدة.
- ويُوضّح الشكل (1-1) مكونات أنظمة إدارة الهوية والصلاحيات، إذ تُشكّل هذه المكونات البنية الأساسية التي يعتمد عليها التحكم بالوصول في البيئات السحابية. حيث يتم تعريف المستخدمين وتنظيمهم ضمن مجموعات، ثم إسناد أدوار تحتوي على مجموعة من الصلاحيات المحددة عبر سياسات وصول. يتيح هذا الفصل البنيوي مرونة عالية في الإدارة، ويساعد في تقليل الاعتماد على التهيئة الفردية، إلا أنه قد يؤدي إلى تعقيد متزايد في حال غياب الضبط المنهجي للعلاقات بين هذه المكونات.



الشكل 1-1 المكونات الأساسية لأنظمة إدارة الهوية والصلاحيات (IAM) [8]

1.2.3 آليات التحقق من الهوية (Authentication) [8]

تُعد آليات التحقق من الهوية عنصراً أساسياً في أنظمة إدارة الهوية والصلاحيات، إذ تهدف إلى التأكد من أن المستخدم أو النظام الذي يطلب الوصول هو بالفعل الجهة المصرّح لها. وتعتمد البيئات السحابية الحديثة على مجموعة من تقنيات المصادقة لتعزيز مستوى الأمان وتقليل مخاطر الوصول غير المصرّح به.

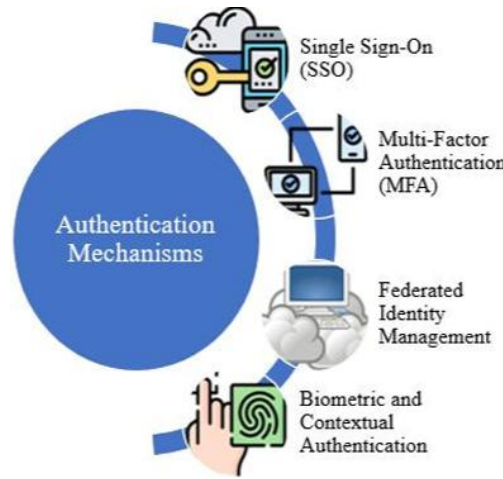
ومن أبرز آليات التحقق المعتمدة في البيئات السحابية الحديثة ما يلي:

- التحقق المعتمد على كلمة المرور (Password-based Authentication): يُعد من أقدم وأكثر أساليب التحقق انتشاراً، حيث يعتمد على مطابقة اسم المستخدم مع كلمة مرور سرّية. وعلى الرغم من سهولة تطبيقه وانخفاض تكلفته، إلا أنه يُعد محدود الفاعلية في مواجهة التهديدات

الحديثة، نظراً لإمكانية تعرّض كلمات المرور لهجمات التخمين، والتصيّد الإلكتروني، أو إعادة الاستخدام عبر أنظمة متعددة.

- المصادقة متعددة العوامل (Multi-Factor Authentication – MFA): تعتمد على استخدام أكثر من عامل تحقق مستقل، مثل الجمع بين شيء يعرفه المستخدم (كلمة المرور)، وشيء يملكه (هاتف ذكي أو رمز مؤقت)، أو سمة حيوية خاصة به. يساهم هذا الأسلوب في تعزيز مستوى الأمان بشكل ملحوظ، إذ يقلل من احتمالية اختراق الحسابات حتى في حال تسريب بيانات الاعتماد الأساسية.
- تسجيل الدخول الموحد (Single Sign-On – SSO): يتيح للمستخدم المصادقة مرة واحدة للوصول إلى عدة أنظمة وخدمات مترابطة، مما يحسن تجربة المستخدم ويقلل من الحاجة إلى إدارة كلمات مرور متعددة. إلا أن هذا الأسلوب يتطلب ضوابط أمنية صارمة، نظراً لاعتماده على نقطة مصادقة مركزية قد تشكل هدفاً جذاباً للهجمات في حال عدم تأمينها بشكل كافٍ.
- إدارة الهوية الموحدة (Federated Identity Management): تسمح للمستخدمين بالوصول إلى الخدمات السحابية باستخدام بيانات اعتماد من مزود هوية خارجي موثوق، مثل مزودات الهوية المؤسسية أو التجارية، مما يبسط إدارة الحسابات ويقلل من تكرار بيانات الاعتماد.
- المصادقة البيومترية والسياقية (Biometric and Contextual Authentication): تعتمد المصادقة البيومترية على خصائص حيوية فريدة مثل بصمة الإصبع أو التعرف على الوجه، في حين تقوم المصادقة السياقية بتقييم عوامل إضافية مثل الموقع الجغرافي، نوع الجهاز، ونمط السلوك، لتقدير مدى موثوقية طلب الوصول.

ويُوضّح الشكل (2-1) آليات التحقق من الهوية الشائعة في أنظمة إدارة الهوية والصلاحيات، مبيّناً تكامل هذه الأساليب في تعزيز مستوى الأمان والتحكم بالوصول داخل البيئات السحابية الحديثة.



الشكل 2-1 آليات التحقق من الهوية في أنظمة إدارة الهوية والصلاحيات [8]

1.2.4 آليات التفويض ونماذج التحكم بالوصول (Authorization) [8]

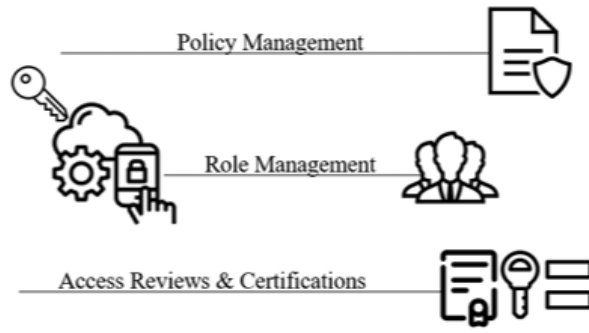
تُعد آليات التفويض (Authorization) المرحلة التي تلي عملية التحقق من الهوية في أنظمة إدارة الهوية والصلاحيات، حيث يتم من خلالها تحديد الصلاحيات الممنوحة للكيان المصادق عليه، وما إذا كان مسموحاً له تنفيذ عمليات محددة أو الوصول إلى موارد معينة داخل النظام. وتُعد هذه الآليات عنصراً أساسياً في حماية الموارد السحابية من الوصول غير المصرح به أو الاستخدام المفرط للصلاحيات.

تعتمد أنظمة IAM في تنفيذ التفويض والتحكم بالوصول على مجموعة من المكونات التنظيمية، تشمل السياسات، الأدوار، وآليات المراجعة الدورية للصلاحيات. حيث تُستخدم السياسات (Policies) لتحديد القواعد التي تحكم الوصول إلى الموارد، ويتم إسنادها إلى المستخدمين أو المجموعات أو الأدوار. أما إدارة الأدوار (Role Management)، فتُمثل الأساس في نماذج التحكم بالوصول المعتمدة على الدور، إذ يتم ربط الصلاحيات بالوظائف والمسؤوليات الفعلية للمستخدمين داخل المؤسسة. وتُستكمل هذه الآليات من خلال مراجعات الوصول الدورية وعمليات الاعتماد (Access Reviews and Certifications)، التي تهدف إلى التأكد من أن الصلاحيات الممنوحة لا تزال متوافقة مع متطلبات العمل والسياسات الأمنية المعتمدة.

ومن أبرز نماذج التحكم بالوصول المستخدمة في أنظمة إدارة الهوية والصلاحيات ما يلي:

- التحكم بالوصول المعتمد على الدور (Role-Based Access Control – RBAC): يعتمد هذا النموذج على إسناد الصلاحيات إلى أدوار محددة، ثم ربط المستخدمين بهذه الأدوار وفق وظائفهم ومسؤولياتهم داخل المؤسسة. يساهم RBAC في تبسيط إدارة الصلاحيات وتحقيق مبدأ أقل الامتيازات، إلا أن استخدامه في البيئات الكبيرة والديناميكية قد يؤدي إلى ما يُعرف بمشكلة انفجار الأدوار، حيث يزداد عدد الأدوار بشكل يصعب إدارته أو مراجعته يدوياً.
- التحكم بالوصول المعتمد على السمات (Attribute-Based Access Control – ABAC): يرتكز هذا النموذج على اتخاذ قرارات الوصول بناءً على مجموعة من السمات المرتبطة بالمستخدم، المورد، أو السياق التشغيلي، مثل الموقع الجغرافي أو وقت الوصول. يوفر ABAC مرونة أعلى مقارنةً بـ RBAC، لكنه يتطلب سياسات أكثر تعقيداً وإدارة دقيقة للسمات.
- النماذج المعتمدة على العلاقات (Relationship-Based Access Models): تعتمد هذه النماذج على تحليل العلاقات بين الكيانات المختلفة داخل النظام، مثل المستخدمين، الأدوار، السياسات، والموارد. يتيح هذا الأسلوب تمثيل مسارات الوصول غير المباشرة واكتشاف سيناريوهات تصعيد الصلاحيات التي قد لا تكون واضحة عند استخدام النماذج التقليدية، مما يجعله مناسباً لتحليل البيانات السحابية المعقدة.

ويُوضّح الشكل (1-3) المكونات الأساسية لعمليات التفويض والتحكم بالوصول في أنظمة إدارة الهوية والصلاحيات، مبيّناً دور السياسات، إدارة الأدوار، ومراجعات الوصول في ضبط الصلاحيات وتعزيز أمن الموارد السحابية



الشكل 1-3 آليات التفويض والتحكم بالوصول في أنظمة إدارة الهوية والصلاحيات [8]

1.2.5 تهيئة أنظمة IAM (IAM Configuration) [8]

تشير تهيئة أنظمة إدارة الهوية والصلاحيات (IAM Configuration) إلى الإعدادات المقصود والمنهجي لسياسات الوصول في البيئات السحابية، بما يضمن منح الصلاحيات للمستخدمين والكيانات المختلفة وفق متطلبات العمل الفعلية وبما يتوافق مع السياسات الأمنية المعتمدة. وتعتمد التهيئة الصحيحة لأنظمة IAM على تنظيم واضح للعلاقات بين المستخدمين، المجموعات، الأدوار، والصلاحيات، مع الالتزام بمبدأ أقل امتياز (Least Privilege)، بحيث لا يحصل أي كيان على صلاحيات تتجاوز نطاق مسؤولياته الوظيفية.

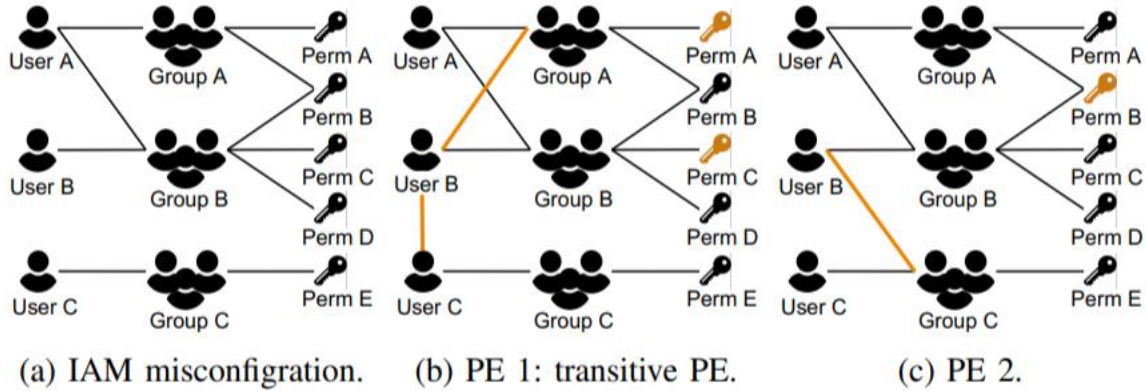
1.2.6 أخطاء إعداد IAM (IAM Misconfigurations) [7]

تُعد أخطاء إعداد أنظمة إدارة الهوية والصلاحيات (IAM Misconfigurations) من أخطر التهديدات الأمنية في البيئات السحابية، إذ غالباً ما تؤدي إلى تعريض الموارد أو البيانات الحساسة للوصول غير المصرح به. وتشير الدراسات والتقارير الأمنية إلى أن سوء التهيئة في سياسات IAM يُعد من الأسباب الرئيسية لحوادث الاختراق، حيث يعتمد المهاجمون في كثير من الحالات على استغلال الصلاحيات الممنوحة بشكل غير مقصود بدلاً من البحث عن ثغرات تقنية معقدة.

ومن أكثر أخطاء إعداد IAM ما يلي:

- منح صلاحيات أكثر من اللازم (Over-Permission / Excessive Privileges): يحدث هذا الخطأ عند منح المستخدمين أو الخدمات صلاحيات تتجاوز متطلبات مهامهم الفعلية، مما يزيد من مساحة الهجوم ويتيح إمكانية استغلال هذه الصلاحيات في حال اختراق الحساب.
- الحسابات غير النشطة (Inactive Accounts): بقاء حسابات مستخدمين أو خدمات لم تعد قيد الاستخدام دون تعطيلها يشكل نقطة دخول خفية للمهاجمين، خاصة في حال عدم مراقبة هذه الحسابات أو تحديث بياناتها.
- سوء إعداد السياسات (Misconfigured Policies): يتضمن ذلك إنشاء سياسات وصول غير مقيدة أو عامة، تسمح بالوصول إلى موارد متعددة دون ضوابط دقيقة، مما يسهل تجاوز آليات الحماية المعتمدة.
- غياب التنظيم الهرمي للأدوار والسياسات: عدم فصل الأدوار وتنظيمها بشكل هرمي واضح يؤدي إلى تعقيد إدارة الصلاحيات، ويزيد من احتمالية تداخل الامتيازات وصعوبة مراجعتها أو تدقيقها.

يوضح الشكل (4-1) مثالاً لحالات سوء إعداد أنظمة إدارة الهوية والصلاحيات (IAM Misconfiguration)، حيث لا يمتلك المستخدم في الحالة الأساسية صلاحية مباشرة، إلا أن طريقة تنظيم المجموعات وسياسات الصلاحيات تؤدي إلى إنشاء مسارات وصول غير مقصودة. نلاحظ في الحالة (a)، تظهر تهيئة IAM تتضمن عدة مستخدمين ينتمون إلى مجموعات مختلفة وفي الحالة (b)، نتج تصعيد صلاحيات انتقالي (Transitive Privilege Escalation)، حيث يحصل أحد المستخدمين على صلاحية إضافية نتيجة انتمائه غير المباشر إلى مجموعة تمتلك صلاحية أعلى، دون وجود تفويض مباشر أو صريح لهذه الصلاحية. أما في الحالة (c)، فيتضح كيف يمكن أن يمتد هذا التصعيد ليشمل مستخدمين آخرين، بحيث تؤدي العلاقات الانتقالية المتراكمة إلى منح صلاحيات حساسة.



الشكل 4-1 سوء إعداد IAM [15]

تُظهر هذه الأمثلة أن أخطاء إعداد IAM قد تكون غير واضحة عند مراجعة الصلاحيات بشكل مباشر، مما يؤكد الحاجة إلى أساليب تحليل تعتمد على نمذجة العلاقات واكتشاف مسارات الوصول غير المتوقعة.

1.2.7 تأثير سوء إعداد IAM على الأمن السحابي [7]

لا يقتصر أثر أخطاء إعداد أنظمة إدارة الهوية والصلاحيات على الجوانب التنظيمية فقط، بل ينعكس بشكل مباشر على مستوى أمن البيئات السحابية ككل. إذ يؤدي سوء ضبط الصلاحيات أو غياب القيود المناسبة إلى إضعاف آليات التحكم بالوصول، مما يتيح للمهاجمين استغلال الحسابات أو الخدمات الحساسة بطرق غير مشروعة. وتشير الدراسات إلى أن نسبة كبيرة من الحوادث الأمنية في البيئات السحابية ترتبط بشكل مباشر بأخطاء في سياسات IAM وإدارة الامتيازات.

ومن أبرز التأثيرات الأمنية الناتجة عن سوء إعداد IAM ما يلي:

- اختراق البيانات (Data Breach): نتيجة منح صلاحيات وصول غير مقيّدة إلى موارد التخزين أو قواعد البيانات.

- تصعيد الصلاحيات (Privilege Escalation): حيث يستغل المهاجم صلاحيات محدودة للوصول إلى موارد ذات امتيازات أعلى.

- تعطيل الخدمات (Denial of Service): من خلال الوصول غير المصرّح به إلى إعدادات الشبكة أو الموارد الحرجة.

وبناءً على ذلك، فإن أي ضعف في تهيئة أنظمة IAM يمكن أن يهدد سرية البيانات، سلامة الموارد، وتوفر الخدمات السحابية، مما يجعل من الإدارة الدقيقة للصلاحيات عنصراً أساسياً في حماية البنية السحابية.

1.2.8 أهمية تحليل أنظمة IAM في البيئات السحابية [8]

مع التوسع المستمر في استخدام البيئات السحابية وتعقّد بنيتها التشغيلية، أصبحت أنظمة إدارة الهوية والصلاحيات أكثر تعقيداً من حيث العلاقات بين المستخدمين، الأدوار، السياسات، والموارد. هذا التعقيد يجعل من الصعب الاعتماد على المراجعة اليدوية لاكتشاف أخطاء التهيئة أو الصلاحيات غير الضرورية، خاصة في البيئات الديناميكية التي تشهد تغيّرات مستمرة في الأدوار الوظيفية والخدمات.

يُسهّم تحليل أنظمة IAM في توفير رؤية شاملة لبنية الصلاحيات، من خلال فحص العلاقات البنوية واكتشاف المسارات غير المباشرة للوصول، والتي قد تؤدي إلى تراكم الامتيازات (Privilege Creep) بمرور الوقت. كما يُعد التحليل الساكن (Static Analysis) أداة فعّالة لتقييم سياسات IAM قبل تطبيقها فعلياً، مما يسمح بالكشف المبكر عن الثغرات المحتملة وتقليل الاعتماد على المعالجة اللاحقة للحوادث الأمنية.

وتشير الدراسات الحديثة إلى أن اعتماد أدوات تحليل منهجية لأنظمة IAM يُعد ضرورة أساسية لضمان الالتزام بمبدأ أقل الامتيازات، وتحسين مستوى الأمان في البيئات السحابية المعقّدة، خاصة في ظل التوسع المستمر في الخدمات والموارد السحابية.

1.2.9 دور IAM في تعزيز أمن السحابة [5]

تعتمد معظم الخدمات السحابية الحديثة على الهوية الرقمية كعنصر أساسي لاتخاذ قرارات الوصول إلى الموارد. ومع تراجع فعالية نماذج الحماية التقليدية القائمة على حدود الشبكة، أصبحت IAM تمثل خط الدفاع الأول في حماية الأنظمة السحابية من الوصول غير المصرّح به.

يساهم التطبيق السليم لسياسات IAM في تقليل مساحة الهجوم (Attack Surface) من خلال تقييد الصلاحيات وفق مبدأ أقل الامتيازات، وضمان الفصل بين المهام، ومنع إساءة استخدام الحسابات ذات الامتيازات العالية. كما يتيح دمج IAM مع آليات تسجيل السجلات والمراقبة المستمرة تعزيز القدرة على تتبع الأنشطة المشبوهة، والكشف المبكر عن محاولات الاختراق أو إساءة استخدام الصلاحيات.

وبذلك، لا تقتصر وظيفة أنظمة IAM على إدارة المستخدمين والصلاحيات فحسب، بل تشكّل مكوناً استراتيجياً في البنية الأمنية السحابية، يساهم في تحسين مستوى الحماية، وتعزيز الامتثال للسياسات والمعايير الأمنية، ودعم استمرارية الخدمات في البيئات السحابية الحديثة.

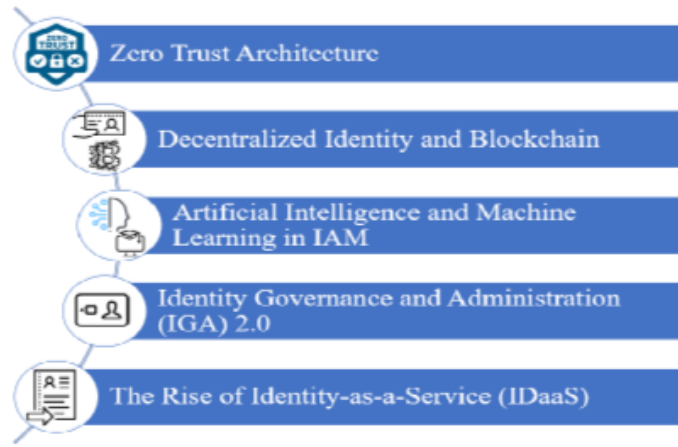
1.2.10 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات (Future Trends in IAM) [8]

مع التوسع المتزايد في اعتماد الخدمات السحابية وتنامي التهديدات السيبرانية، تشهد أنظمة إدارة الهوية والصلاحيات تطوراً مستمراً لمواكبة متطلبات الأمن الحديثة وتحسين كفاءة الإدارة. وتشير الدراسات الحديثة إلى ظهور مجموعة من الاتجاهات التي تشكل الجيل القادم من أنظمة IAM، وتركز بشكل أساسي على تعزيز الأمان، تحسين تجربة المستخدم، وأتمتة العمليات الإدارية.

من أبرز هذه الاتجاهات:

- **بنية الثقة الصفرية (Zero Trust Architecture):** تعتمد على مبدأ عدم الثقة الضمنية بأي كيان داخل أو خارج الشبكة، وفرض التحقق المستمر من الهوية والصلاحيات قبل السماح بأي وصول إلى الموارد.
- **الهوية اللامركزية (Decentralized Identity):** تهدف إلى منح المستخدمين سيطرة أكبر على هوياتهم الرقمية، وتقليل الاعتماد على مزودي الهوية المركزيين، مما يعزز الخصوصية ويحد من مخاطر الاختراق واسعة النطاق.
- **الذكاء الاصطناعي وتعلم الآلة في IAM (Artificial Intelligence and Machine Learning in IAM):** تُستخدم هذه التقنيات لتحليل أنماط السلوك، واكتشاف الأنشطة غير الطبيعية، ودعم اتخاذ قرارات وصول ديناميكية قائمة على المخاطر.
- **حوكمة الهوية وإدارتها المتقدمة (Identity Governance and Administration – IGA 2.0):** تركز على أتمتة عمليات مراجعة الصلاحيات، إدارة دورة حياة الهوية، وضمان الامتثال المستمر للسياسات والمعايير التنظيمية.
- **الهوية كخدمة (Identity-as-a-Service – IDaaS):** تعكس هذا الاتجاه انتقال أنظمة IAM إلى نماذج خدمية قائمة على السحابة، تتيح مرونة أعلى في النشر، وتخفف العبء الإداري عن المؤسسات.

ويُوضّح الشكل (1-5) أبرز الاتجاهات المستقبلية في أنظمة إدارة الهوية والصلاحيات، مبيّناً المسارات التي يتجه نحوها تطور IAM لمواجهة التحديات الأمنية المتزايدة في البيئات السحابية الحديثة.



الشكل 1-5 الاتجاهات المستقبلية في إدارة الهوية والصلاحيات [8]

1.3 أدوات تحليل IAM السحابية (IAM Analysis Tools) [8]

مع التوسّع المستمر في استخدام البيانات السحابية وتعقّد بنيتها التشغيلية، ظهرت أدوات تحليل IAM السحابية بوصفها حلاً متخصصاً تهدف إلى فحص سياسات الهوية والصلاحيات بشكل منهجي، والكشف المبكر عن المخاطر الأمنية قبل استغلالها. تعتمد هذه الأدوات على تحليل بنية IAM ككل، من خلال دراسة العلاقات المباشرة وغير المباشرة بين مكونات النظام، بما يتيح اكتشاف الصلاحيات الزائدة، وتداخل الامتيازات، والمسارات غير المقصودة التي قد تؤدي إلى تصعيد الصلاحيات.

تشير الدراسات الحديثة إلى أن أدوات تحليل IAM التي تجمع بين التحليل البنوي والنهج الاستباقي تُعد من أكثر الأساليب فاعلية في البيانات السحابية المعقّدة، حيث توفر رؤية شاملة لبنية الصلاحيات وتدعم تطبيق مبدأ أقل الامتيازات (Least Privilege) بشكل أكثر دقة، مما يساهم في تحسين مستوى الأمن وتقليل الاعتماد على الاستجابة اللاحقة للحوادث الأمنية.

1.4 سياسات إدارة الهوية والصلاحيات (IAM Policies) [8]

تُعد سياسات إدارة الهوية والصلاحيات (IAM Policies) المكوّن الأساسي الذي يُحدد كيفية التحكم بالوصول إلى الموارد في البيانات السحابية. تمثل هذه السياسات مجموعة من القواعد الرسمية التي تُعرّف بشكل دقيق العمليات المسموح بها أو الممنوعة على موارد محددة، وتُستخدم لضبط صلاحيات المستخدمين، الأدوار، والخدمات بطريقة منهجية وقابلة للتدقيق. تعتمد سياسات IAM على مبدأ المنع الافتراضي (Default Deny)، حيث يُرفض أي طلب وصول ما لم يتم السماح به صراحةً، مما يعزز مبدأ أقل الامتيازات ويحد من مخاطر إساءة استخدام الصلاحيات.

تنقسم سياسات IAM في البيانات السحابية الحديثة إلى عدة أنواع رئيسية، من أبرزها:

- السياسات المدمجة (Inline Policies): وهي سياسات تُربط مباشرةً بمستخدم، مجموعة، أو دور محدد، وتكون مخصصة لهذا الكيان فقط. تُستخدم عادةً عند الحاجة إلى صلاحيات خاصة لا يُراد مشاركتها مع كيانات أخرى، وتُحذف تلقائياً عند حذف الكيان المرتبط بها.
- السياسات المُدارة (Managed Policies): سياسات قابلة لإعادة الاستخدام يمكن ربطها بعدة مستخدمين أو أدوار في الوقت نفسه. تسهّل هذه السياسات عملية الإدارة، حيث إن أي تعديل عليها ينعكس مباشرة على جميع الكيانات المرتبطة بها، مما يضمن الاتساق في تطبيق الصلاحيات.

- حدود الصلاحيات (Permissions Boundaries): تُستخدم كطبقة إضافية لتقييد الحد الأقصى للصلاحيات التي يمكن أن يحصل عليها مستخدم أو دور، حتى في حال وجود سياسات أخرى تمنحه صلاحيات أوسع. تُعد هذه الآلية مهمة في سيناريوهات التفويض الإداري ومنع تصعيد الصلاحيات غير المقصود.
 - سياسات التحكم على مستوى المؤسسة (Service Control Policies – SCPs): تُطبق على مستوى الحسابات أو الوحدات التنظيمية، وتهدف إلى فرض قيود عامة تحدد ما هو مسموح أو غير مسموح ضمن النطاق المؤسسي، دون منح صلاحيات مباشرة بحد ذاتها.
 - السياسات المعتمدة على الموارد (Resource-Based Policies): تُربط مباشرة بالموارد السحابية نفسها، مثل خدمات التخزين أو الرسائل، وتُستخدم غالباً في سيناريوهات الوصول بين حسابات مختلفة، حيث يتم تحديد من يمكنه الوصول إلى المورد وتحت أي شروط.
- يساهم هذا التنوع في سياسات IAM في توفير مرونة عالية لإدارة الصلاحيات، إلا أنه في الوقت ذاته يزيد من تعقيد البنية الأمنية، مما يجعل سوء التهيئة أو التداخل بين السياسات سبباً رئيسياً لظهور الثغرات الأمنية في البيئات السحابية.

1.5 المصائد الأمنية (Honeypots)

تُعد المصائد الأمنية (Honeypots) أدوات فعّالة في مجال أمن المعلومات، تهدف إلى استدراج المهاجمين وكشف أساليبهم دون تعريض الأنظمة الحقيقية للخطر.

1.5.1 تعريف المصائد الأمنية [9]

المصيدة الأمنية هي نظام معلوماتي مصمم ليبدو كهدف للمهاجم، لكنه في الواقع أداة مراقبة تهدف إلى دراسة تصرفات المهاجم وتحليل تهديداته. يتم نشر هذه الأنظمة بشكل منفصل أو ضمن بيئة حوسبة سحابية لمحاكاة خدمات وتطبيقات حقيقية مثل SSH أو HTTP، بحيث يتم تسجيل أي تفاعل مشبوه معها. الهدف من المصائد لا يقتصر فقط على اكتشاف الهجمات، بل يتعداه إلى:

- تحليل سلوك المهاجمين وتحديد أدواتهم.
- جمع بيانات استخبارات التهديد.
- تحسين آليات الدفاع المستقبلية.

1.5.2 أنواع المصائد الأمنية [10]

تنقسم المصائد الأمنية إلى ثلاثة أنواع رئيسية حسب مستوى التفاعل:

- Low-Interaction Honeypots: تحاكي الخدمات بشكل بسيط دون تنفيذ فعلي لها و تُستخدم لتسجيل محاولات الهجوم السريعة ومنخفضة التعقيد.

- Medium-Interaction Honeypots: توفر تفاعل أعمق مع المهاجم، ما يسمح بجمع المزيد من البيانات حول الأوامر والأنشطة.

- High-Interaction Honeypots: أنظمة حقيقية تُنشر لمراقبة سلوك الهجوم الكامل، وتتيح تحليلاً دقيقاً لتقنيات المهاجمين، لكنها تتطلب عزلاً محكماً بسبب خطورتها العالية.

1.5.3 دور المصائد الأمنية في البيئات السحابية [11]

في بيئة الحوسبة السحابية، تُستخدم المصائد الأمنية كوسيلة فعّالة لرصد التهديدات المستمرة والمتقدمة (Advanced Persistent Threats - APTs). يمكن نشرها في أماكن استراتيجية ضمن بنية الخدمة السحابية، مثل الشبكات الافتراضية (VPCs)، لتحاكي نقاط ضعف واقعية وتسجيل الهجمات. تشمل تطبيقات honeypots السحابية:

- كشف الأنشطة الغير المصرح بها داخل بيئة IAM.
- تحليل سلوك المهاجم عند محاولته التسلل إلى موارد البنية التحتية.

1.5.4 التحديات والمخاطر المرتبطة باستخدام Honeypots [10]

رغم فوائد المصائد الأمنية، إلا أن استخدامها ليس خالياً من التحديات، خصوصاً في البيئة السحابية، ومن أبرزها:

- خطر الاستخدام العكسي (Backdoor): إذا تمكن المهاجم من السيطرة على المصيدة، قد يستخدمها كنقطة انطلاق لهجمات أخرى.
- كشف المصيدة (Detection): المهاجمون المتقدمون يمكنهم أحياناً التعرف على خصائص honeypots وتجنبها.
- تكلفة الإدارة: خاصة في حالات high-interaction honeypots التي تتطلب موارد بشرية وتقنية عالية.

لذلك يجب نشر المصائد ضمن بيئة معزولة بشكل جيد، وباستخدام أدوات مراقبة متقدمة تضمن عدم تحول المصيدة إلى نقطة ضعف.

1.5.5 المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots) [11]

تُعد المصائد الأمنية القائمة على السحابة (Cloud-Based Honeypots) تطويراً للمصائد التقليدية، حيث تستفيد من خصائص الحوسبة السحابية مثل سهولة النشر، المرونة، وقابلية التوسع. على عكس المصائد التقليدية التي تعمل في بيئات محلية محدودة، يمكن نشر المصائد السحابية بسرعة داخل بيئات افتراضية تحاكي خدمات سحابية حقيقية مثل التخزين السحابي، واجهات البرمجة، أو أنظمة إدارة الهوية والصلاحيات.

تتيح هذه المصائد مراقبة محاولات الهجوم وتسجيلها دون التأثير على أنظمة الإنتاج الفعلية، كما يمكن عزلها أو حذفها بسهولة عند الحاجة. وتشير الدراسات إلى أن المصائد السحابية تُعد أكثر ملاءمة للبيئات

الحديثة، خاصة في البنى التي تعتمد على النشر الآلي والخدمات السحابية، لما توفره من قدرة أفضل على رصد الهجمات وتحليلها بشكل آمن وفعال.

يوضح الجدول (1-1) الفروقات الأساسية بين المصائد التقليدية والمصائد القائمة على السحابة، إذ توفر المصيدة السحابية قدرة أعلى في اكتشاف الهجمات المتقدمة، خاصة تلك التي تستهدف أنظمة IAM والبنى السحابية.

جدول 1-1 مقارنة بين المصائد السحابية والتقليدية

وجه المقارنة	المصيدة التقليدية	المصيدة السحابية
بيئة التشغيل	خوادم محلية أو شبكات داخلية	بيئات سحابية افتراضية
قابلية التوسع	محدودة وتحتاج تدخل يدوي	عالية ومرنة ديناميكياً
العزل الأمني	عزل فيزيائي أو منطقي محدود	عزل افتراضي متقدم
سهولة النشر	بطيئة نسبياً	سريعة وآلية
التكيف مع الهجمات	ثابتة	قابلة لإعادة التهيئة تلقائياً
التكامل مع التحليل	محدود	تكامل مباشر مع أنظمة التحليل والسجلات
ملاءمة البيانات الحديثة	منخفضة	عالية جداً

1.6 تصنيف المستخدمين (User Classification)

في أنظمة الأمن السيبراني، من الضروري فهم طبيعة وتصنيفات المستخدمين الذين يتفاعلون مع النظام، سواء أكانوا شرعيين أم خبيثين. يُعد تصنيف المستخدمين أداة أساسية في تحليل السلوك، الكشف عن التهديدات، وبناء آليات دفاعية فعالة تعتمد على فهم النمط السلوكي لكل فئة.

1.6.1 تعريف المستخدم الشرعي (Legitimate User) [8]

هو الشخص أو الكيان الذي يمتلك صلاحيات موثقة للوصول إلى موارد النظام أو الشبكة، وغالباً ما يُحدد ذلك من خلال أنظمة إدارة الهوية والصلاحيات (IAM). يُفترض بهذا المستخدم أن يتصرف ضمن الحدود المسموح بها، وفقاً للدور (Role) أو المهمة التي ينتمي إليها ضمن البنية المؤسسية.

1.6.2 تعريف المهاجم (Attacker) [5]

هو كيان (فرد أو برنامج أو مجموعة) يسعى إلى اختراق النظام، أو تجاوز آليات الحماية الأمنية بهدف الوصول غير المشروع إلى المعلومات أو تعطيل الخدمات.

يمكن أن يتخذ المهاجم عدة أشكال:

- مهاجم خارجي (External Attacker): لا يمتلك صلاحيات، ويحاول التسلل من خارج النظام.

- مهاجم داخلي (Insider Threat): يملك صلاحيات شرعية لكنه يسيء استخدامها عن قصد أو بدون قصد.

يُعد فهم طبيعة المهاجم ضرورياً لتصميم سياسات دفاع متقدمة تتضمن التحقق المتعدد الطبقات، والتسجيل الذكي للسلوكيات، والاستجابة المبكرة للهجمات.

1.7 السجلات (Logs)

تُعد أنظمة تسجيل السجلات جزءاً أساسياً من أي بنية أمنية، حيث تسجل كل الأنشطة التي تحدث في النظام بهدف الرجوع إليها لاحقاً في التحقيقات أو التحليل الأمني.

1.7.1 تعريف السجلات [11]

هي ملفات أو هياكل بيانات تقوم بتوثيق الأحداث والأنشطة التي تحدث داخل الأنظمة والشبكات. تلعب دوراً محورياً في مراقبة النظام، الكشف عن الهجمات، وتحليل الحوادث الأمنية، حيث تُمكن من تتبع نشاط المستخدمين والتطبيقات واكتشاف السلوكيات غير الطبيعية.

1.7.2 نظام تسجيل السجلات (Log Recording Systems) [11]

هو إطار تقني يُستخدم لتوليد، جمع، وتخزين السجلات الناتجة عن الأنظمة والتطبيقات والبنى التحتية. تشمل السجلات بيانات مثل:

- محاولات الدخول
- الأوامر المنفذة
- التنبيهات الأمنية

وتُعد هذه الأنظمة عنصراً محورياً في مراقبة الأنشطة والكشف المبكر عن التهديدات.

1.7.3 مكونات نظام تسجيل السجلات [11]

يتكون نظام السجلات من عنصرين أساسيين:

- العميل (Log Client): وهو الكيان الذي يُنتج السجلات، مثل نظام التشغيل، أو التطبيق، أو المصيدة الأمنية (Honeypot). يقوم بإرسال السجلات إلى الوجهة المحددة.
 - الخادم (Log Server): يُستقبل السجلات ويخزنها.
- ويتم نقل السجلات باستخدام بروتوكولات قياسية مثل Syslog أو تنسيقات حديثة مثل JSON.

1.7.4 آلية تبادل السجلات (Log Transmission Mechanism) [11]

يتم تبادل السجلات بين العناصر المختلفة في نظام التسجيل باستخدام بروتوكولات نقل مخصصة تهدف إلى ضمان السرعة، الموثوقية، والأمان. من أشهر هذه البروتوكولات:

- Syslog (RFC 5424): بروتوكول نصي بسيط يُستخدم على نطاق واسع في أنظمة UNIX/Linux لإرسال السجلات إلى خادم مركزي. تُستخدم تقنيات التشفير (مثل TLS/SSL) لضمان سرية السجلات أثناء النقل، بينما تُستخدم آليات التحقق من السلامة (مثل SHA-256) لضمان عدم التلاعب بها. كما تُطبق سياسات للتحكم بالوصول لضمان ألا يتمكن سوى الكيانات المصرح لها من إرسال أو استقبال السجلات.

الخاتمة

قدّم هذا الفصل خلفية نظرية توضّح كيف أصبحت الهوية الرقمية محور التحكم بالوصول في البيئات السحابية، ولماذا تُعد أخطاء إعداد IAM من أكثر مصادر المخاطر شيوعاً وتأثيراً. كما تناول الفصل دور المصادد الأمنية في استدراج الهجمات ورصدها بشكل آمن، وأهمية السجلات في بناء رؤية تحليلية دقيقة للسلوكيات والأنشطة. وبذلك تم استعراض المفاهيم الأساسية التي يعتمد عليها المشروع نظرياً، والتي تُعد ركائز داعمة لفهم التقنيات المستخدمة وتبرير الاختيارات الأمنية في تصميم النظام المقترح، بما يسهم في كشف السلوك الضار وتعزيز أمن البيئة السحابية.

الفصل الثاني

الدراسات السابقة

2 الفصل الثاني - الدراسات السابقة

يركّز هذا الفصل على استعراض وتحليل الدراسات والأبحاث الحديثة التي تناولت أمن الحوسبة السحابية، مع التركيز على أنظمة إدارة الهوية والصلاحيات (IAM)، أتمتة الأمن السحابي، واستخدام المصائد الأمنية (Honeypots) في كشف التهديدات. يهدف هذا الاستعراض إلى إبراز الاتجاهات البحثية السائدة، وتحديد نقاط القوة والقصور في الحلول المقترحة، وصولاً إلى توضيح الفجوة البحثية التي يسعى هذا المشروع إلى معالجتها من خلال الدمج بين تحليل IAM والمصائد الأمنية ضمن إطار تحليلي موحد.

2.1 الدراسات السابقة

Cloud Security Alliance – Top Threats to Cloud Computing: Deep Dive [12] (2025)

يركّز هذا التقرير الصناعي على تحليل أبرز التهديدات الأمنية في البيئات السحابية اعتماداً على ثماني حوادث واقعية وقعت بين عامي 2023 و 2024. وضّح التقرير إلى أن سوء تكوين سياسات إدارة الهوية والصلاحيات (IAM Misconfigurations) وفشل الحوكمة الأمنية يمثلان المصدر الأساسي لغالبية الحوادث. أظهرت النتائج أن تعطيل المصادقة متعددة العوامل، ومنح الصلاحيات المفرطة، وغياب مبدأ أقل الامتيازات كانت عوامل مشتركة في معظم الاختراقات. تبرز أهمية هذه الدراسة في تأكيدها على الحاجة إلى التحليل الوقائي المؤتمت لسياسات IAM، لكنها لا تتناول الجوانب التنفيذية أو التكامل مع أدوات كشف هجومية مثل المصائد الأمنية.

Microsoft – State of Multicloud Security Report (2024)[13]

يستعرض هذا التقرير واقع أمن البيئات متعددة السُحب من خلال تحليل بيانات ضخمة مأخوذة من منصات AWS و Azure و GCP. ويسلط الضوء على تضخم الهويات، وتراكم الصلاحيات (Permission Creep)، وازدياد عدد المسارات القابلة للاستغلال داخل أنظمة IAM. تشير النتائج إلى أن نسبة صغيرة جداً من الصلاحيات تُستخدم فعلياً، في حين يشكل الباقي سطح هجوم غير ضروري. تبرز أهمية التقرير في تقديم مؤشرات كمية حديثة حول مخاطر IAM، لكنه يظل تقريراً وصفيّاً يفتقر إلى نماذج تحليل هجومية أو تكامل مع آليات خداع مثل Honeypots.

Cloud Identity and Access Management (IAM) Automation(2025) [14]

تناقش هذه الدراسة التحول من إدارة الهوية التقليدية إلى أنظمة IAM المؤتمتة في البيئات السحابية الحديثة. تؤكد الورقة أن الأتمتة تساهم في تقليل الأخطاء البشرية، وتسريع عمليات منح وسحب الصلاحيات، وتحسين الامتثال الأمني. تعتمد الدراسة على مفاهيم مثل Infrastructure as Code والتكامل مع واجهات البرمجة السحابية، وتشير إلى أهمية دمج IAM المؤتمت مع أنظمة مراقبة مثل SIEM. تدعم هذه

الدراسة الأساس النظري لاعتماد التحليل الآلي في المشروع، إلا أنها لا تقدّم توصيفاً لكيفية اكتشاف الهجمات أو ربط التحليل بسلوك المهاجمين.

Fixing Privilege Escalations in Cloud Access Control with MaxSAT and Graph Neural Networks(2023) [15]

تعالج هذه الدراسة مشكلة تصعيد الصلاحيات الناتج عن سوء إعداد سياسات IAM في البيئات السحابية، مع التركيز على إصلاح هذه الأخطاء وليس فقط اكتشافها. تقترح الورقة أداة جديدة تُدعى IAMPERE قادرة على توليد تعديلات شبه مثالية (Approximately Minimal Patches) لمعالجة عدد أكبر من أنماط تصعيد الصلاحيات مقارنة بالأدوات السابقة.

تعتمد المنهجية على نمذجة المشكلة باستخدام MaxSAT، مع الاستعانة بالشبكات العصبية البيانية (GNN) لتقليل مساحة البحث وتحسين القابلية للتوسع. تُظهر النتائج تفوق الأداة المقترحة من حيث عدد الحالات المُعالجة وحجم التعديلات المطلوبة. تمثل هذه الدراسة مرجعاً مهماً لدعم التحليل البنوي لمسارات تصعيد الصلاحيات في IAM، لكنها لا تربط النتائج بسلوك هجومي فعلي.

Cloud Security Automation Through Symmetry: Threat Detection and Response – Pitkar(2025) [16]

تطرح هذه الدراسة إطاراً متقدماً لأتمتة الأمن السحابي والقائم على تحقيق التوازن بين الكشف الآلي للتهديدات والاستجابة التلقائية لها. تقترح بنية متعددة الطبقات تدمج أنظمة SIEM و SOAR و XDR مع تقنيات الذكاء الاصطناعي، بهدف تقليل زمن الاستجابة وتحسين دقة الكشف. تبرز أهمية الدراسة في تقديم نموذج معماري متكامل للأتمتة الأمنية، إلا أن تركيزها يبقى عاماً ولا يتناول تحليل IAM بعمق أو دمج مع بيانات خداع هجومية مثل المصائد الأمنية.

Cyber Threat Detection with Honeypots – Valiyev(2025) [17]

تمثل هذه الدراسة نموذجاً تطبيقياً لنشر المصائد الأمنية باستخدام منصة T-Pot المفتوحة المصدر لرصد الهجمات السيبرانية في الزمن الحقيقي. اعتمدت الورقة على جمع وتحليل بيانات الهجمات عبر ELK Stack، وتمكنت من توثيق أنماط هجومية واقعية وثغرات شائعة. تبرز قوة الدراسة في الجانب التطبيقي العملي، إلا أنها تفقر إلى الأتمتة التحليلية، ولا تتضمن أي تكامل مع أنظمة IAM أو آليات ربط بين سلوك المهاجم والصلاحيات المستهدفة.

Advancing Cybersecurity with Honeypots and Deception Strategies – Pitkar (2025) [18]

تقدّم هذه الدراسة مقارنة تجريبية بين عدة أنظمة Honeypot مفتوحة المصدر، مع تقييم أدائها من حيث نطاق الكشف، الموثوقية، وقابلية التوسع. توصلت النتائج إلى تفوّق بعض المصائد مثل Cowrie و Dionaea، وأكدت أهمية دمج المصائد مع أنظمة أمنية أخرى لتحسين فعالية الرصد. تساهم هذه الدراسة

في ترسيخ الدور الدفاعي للمصائد الأمنية، لكنها لا تربط نتائج الهجمات بتحليل الهوية أو مسارات تصعيد الصلاحيات داخل أنظمة IAM.

SkyEye: When Your Vision Reaches Beyond IAM Boundary Scope in AWS Cloud(2025) [19]

تعد هذه الدراسة من أبرز الأبحاث المتقدمة في تحليل سوء تكوين IAM داخل بيئة AWS. تقترح إطاراً تحليلياً جديداً يعتمد على التعداد التعاوني متعدد الهويات لاكتشاف مسارات تصعيد الصلاحيات غير المباشرة. أثبتت النتائج قدرة النظام على كشف ثغرات لم تتمكن أدوات أخرى من اكتشافها. تمثل هذه الدراسة الأساس العلمي لفكرة IAM Analyzer، لكنها تركز على التحليل الهجومي فقط، دون ربط النتائج بسلوك هجومي فعلي أو دمجها مع مصائد أمنية أو أنظمة استجابة.

Dynamic Honeypot Deployment for Enhanced Cybersecurity – Aljuneidi (2025) [20]

تقترح هذه الدراسة إطاراً لمصيدة أمنية ديناميكية تهدف إلى معالجة محدودية المصائد الثابتة التي قد يتم اكتشافها من قبل المهاجمين. تعتمد المنهجية على تغيير الهوية الشبكية للمصيدة تلقائياً (مثل عنوان IP و MAC واسم المضيف ومفاتيح التشفير) بهدف زيادة صعوبة اكتشافها.

تم دمج أدوات مفتوحة المصدر مثل Snort و OpenCanary و Elastic Stack ضمن نظام تفاعلي يتكيف مع التهديدات. أظهرت نتائج التقييم تحسناً واضحاً في كفاءة الكشف وتقليل الإنذارات الكاذبة مقارنة بالمصائد التقليدية لكنها لا تتناول أنظمة IAM أو تحليل الصلاحيات.

CIS Benchmarks: Enhancing Security Configurations in Multi-Cloud Infrastructures(2024) [21]

تركز هذه الدراسة على دور CIS Benchmarks في تحسين إعدادات الأمان ضمن البيئات متعددة السُحب، من خلال توفير مجموعة من أفضل الممارسات القياسية لتقليل المخاطر وتعزيز الامتثال الأمني. توضّح الورقة كيف يمكن استخدام هذه المعايير لتوحيد سياسات الأمان، والحد من أخطاء التهيئة الشائعة، خاصة في البيئات التي تجمع بين مزودين سحابيين مختلفين.

كما تناقش التحديات المرتبطة بتطبيق هذه المعايير في البيئات المعقدة، وتؤكد على أهمية الأتمتة في فرض الإعدادات الأمنية وتقليل الأخطاء البشرية.

2.2 مقارنة بين المشروع والدراسات السابقة

بعد استعراض الدراسات والأبحاث الحديثة في مجال أمن الحوسبة السحابية، اتضح أن معظم الأعمال السابقة ركزت على محور واحد من محاور الأمن السحابي، مثل تحليل أنظمة إدارة الهوية والصلاحيات (IAM)، أو أتمتة الضبط الأمني، أو استخدام المصائد الأمنية (Honeypots) لرصد الهجمات. وعلى الرغم من القيمة العلمية والتطبيقية لهذه الدراسات، إلا أن كلاً منها عالج المشكلة من زاوية جزئية دون تقديم إطار متكامل يجمع بين التحليل النبوي للصلاحيات والسلوك الهجومي الفعلي.

تبين المقارنة أن الدراسات المعنية بـ IAM ركزت بشكل أساسي على اكتشاف أو إصلاح أخطاء التهيئة ومسارات تصعيد الصلاحيات، غالباً باستخدام أساليب تحليل ساكنة أو نماذج رسم بياني، لكنها لم تربط نتائج التحليل بمحاولات هجوم حقيقية أو سلوك المهاجم داخل البيئة السحابية. في المقابل، ركزت دراسات المصائد الأمنية على جمع بيانات الهجمات وتحليلها، إلا أنها تعاملت مع المصيدة كنظام معزول عن سياق الصلاحيات والهوية، دون الاستفادة من معلومات IAM لفهم دوافع الهجوم أو الأهداف المستهدفة.

أما التقارير الصناعية والمعايير الأمنية، فقد ساهمت في إبراز حجم المخاطر المرتبطة بسوء إعداد IAM وتضخم الصلاحيات، وقدمت إرشادات عامة لتحسين الضبط الأمني.

ينطلق المشروع المقترح من هذه الفجوة البحثية، حيث يهدف إلى الدمج بين تحليل IAM الساكن والمصائد الأمنية ضمن بيئة سحابية، بحيث يتم ربط أخطاء التهيئة ومسارات تصعيد الصلاحيات بسلوك هجومي فعلي يتم رصده وتحليله. هذا التكامل يتيح فهماً أعمق لكيفية استغلال الثغرات، ويقدم قيمة مضافة مقارنة بالدراسات السابقة التي عالجت كل عنصر بشكل منفصل.

يوضح الجدول (1-2) مقارنة بين المشروع المقترح والدراسات السابقة، اعتماداً على مجموعة من المعايير البحثية الشائعة في مراجعات الأدبيات العلمية. تشمل هذه المعايير عنوان الدراسة، الهدف الرئيسي، النتائج الأساسية، نقاط القوة المنهجية، نقاط الضعف أو القيود، إضافة إلى علاقة كل دراسة بالمشروع الحالي. مما يبرز بوضوح الإضافة العلمية والتطبيقية التي يقدمها هذا البحث.

جدول 1-2 المقارنة بين الدراسات

العنوان	الهدف الرئيسي	النتائج	نقاط القوة	نقاط الضعف	علاقة الورقة بالمشروع
Cloud Security Alliance – Top Threats to Cloud Computing: Deep Dive (2025)	تحديد أبرز التهديدات الأمنية في البيئات السحابية اعتمادًا على حوادث واقعية	أثبت أن سوء إعداد IAM وفشل الحوكمة يمثلان السبب الرئيسي لغالبية الاختراقات السحابية	يستند إلى حوادث حقيقية ويقدم رؤية شاملة على مستوى الصناعة	تقرير وصفي لا يقدم نماذج تحليل أو حلول تنفيذية	يدعم الدافع البحثي للمشروع ويبرز التركيز على IAM Misconfigurations
Microsoft – State of Multicloud Security Report (2024)	تحليل وضع الأمن في البيئات متعددة السحب	كشف تضخم الهويات وتراكم الصلاحيات ووجود مسارات وصول غير ضرورية	بيانات كمية واسعة من بيانات حقيقية متعددة السحب	لا يقدم آليات تحليل بنوية أو ربط بالسلوك الهجومي	يبرز مشكلة Privilege Creep التي يستهدفها المشروع بالتحليل البنوي
Cloud Identity and Access Management (IAM) Automation (2025)	دراسة أثر أتمتة IAM في البيئات السحابية الحديثة	أظهرت أن الأتمتة تقلل الأخطاء البشرية وتحسن الامتثال الأمني	تركيز واضح على الأتمتة والتكامل مع الأنظمة السحابية	غياب تحليل مسارات تصعيد الصلاحيات أو سلوك المهاجم	تدعم اعتماد التحليل الآلي داخل المشروع
Fixing Privilege Escalations in Cloud Access Control with MaxSAT and GNNs (2023)	إصلاح مسارات تصعيد الصلاحيات الناتجة عن سوء إعداد IAM	أثبتت فاعلية أداة IAMPERE في توليد تعديلات شبه مثالية للسياسات	تحليل رسمي متقدم باستخدام MaxSAT وGNN	تركيز على الإصلاح دون ربط بسلوك هجومي أو بيئة خداع	يدعم التحليل البنوي لمسارات التصعيد التي يعتمدها المشروع
Cloud Security Automation Through Symmetry – Pitkar (2025)	أتمتة كشف التهديدات والاستجابة في البيئات السحابية	تقليل زمن الاستجابة وتحسين دقة الكشف	نموذج معماري متكامل للأتمتة الأمنية	معالجة عامة دون تركيز على IAM أو Honeypots	يبرز أهمية الأتمتة التي يعتمدها المشروع جزئيًا
Cyber Threat Detection with Honeypots – Valiyev (2025)	استخدام المصائد الأمنية لرصد الهجمات في الزمن الحقيقي	توثيق أنماط هجومية واقعية باستخدام ELK Stack	تطبيق عملي واقعي للمصائد الأمنية	عدم وجود أتمتة تحليلية أو تكامل مع IAM	يدعم الجانب التطبيقي للمصيدة في المشروع
Advancing Cybersecurity with Honeypots	تقييم أنظمة Honeypot وتقنيات الخداع	تفوق مصائد محددة وتحسين فعالية الرصد	مقارنة تجريبية منهجية بين عدة أدوات	غياب الربط بين الهجوم والصلاحيات أو IAM	يرسخ الدور الدفاعي للمصائد المستخدمة في المشروع

					and Deception Strategies – Pitkar (2025)
يمثل الأساس العلمي لمفهوم IAM Analyzer في المشروع	غياب الربط بسلوك هجومي فعلي	تحليل تعاوني متقدم لمسارات التصعيد	كشف ثغرات لم تتمكن الأدوات التقليدية من اكتشافها	اكتشاف مسارات تصعيد الصلاحيات غير المباشرة في AWS IAM	SkyEye: Beyond IAM Boundary Scope in AWS Cloud (2025)
يدعم فكرة المصيدة المتقدمة المستخدمة في المشروع	IAM لا يتناول أو تحليل الصلاحيات	إطار خداع متكيف وقابل للتوسع	زيادة زمن الكشف وتقليل الإنذارات الكاذبة	تطوير مصيدة ديناميكية تتجنب اكتشاف المهاجم	Dynamic Honeypot Deployment for Enhanced Cybersecurity – Aljuneidi (2025)
تشكل مرجعاً داعماً لضبط الإعدادات وليس للتحليل	لا تكتشف المسارات الهجومية أو السلوك الضار	معايير صناعية معتمدة وقابلة للأتمتة	تقليل أخطاء التهيئة وتعزيز الامتثال	تحسين إعدادات الأمان عبر معايير قياسية	CIS Benchmarks: Enhancing Security Configurations in Multi-Cloud (2024)

تُظهر المقارنة أن الدراسات السابقة تناولت جوانب متفرقة من المشكلة، إما من منظور تحليل أنظمة إدارة الهوية والصلاحيات (IAM)، أو من زاوية استخدام المصادد الأمنية، أو ضمن أطر عامة لأتمتة الأمن السحابي، دون تقديم إطار موحد يربط بين تحليل الصلاحيات وسلوك المهاجم الفعلي داخل البيئة السحابية. وانطلاقاً من هذه الفجوة البحثية، يأتي المشروع المقترح ليقدم مقارنة تكاملية تقوم على الدمج بين تحليل IAM الساكن والمصادد الأمنية ضمن بيئة سحابية تجريبية متكاملة، بما يتيح فهماً أعمق لكيفية استغلال الثغرات وربطها بالسلوك الهجومي الحقيقي.

الخاتمة

قدّم هذا الفصل تحليلاً منهجياً للدراسات والأعمال البحثية الحديثة المرتبطة بأمن الحوسبة السحابية، مع التركيز على أنظمة إدارة الهوية والصلاحيات، أتمتة الأمن السحابي، وتقنيات المصادد الأمنية. أتاح هذا التحليل تحديد الاتجاهات البحثية المعتمدة في معالجة مشكلات سوء إعداد IAM، وآليات اكتشاف مسارات تصعيد الصلاحيات، إضافة إلى الأساليب المستخدمة في رصد السلوك الهجومي عبر المصادد الأمنية.

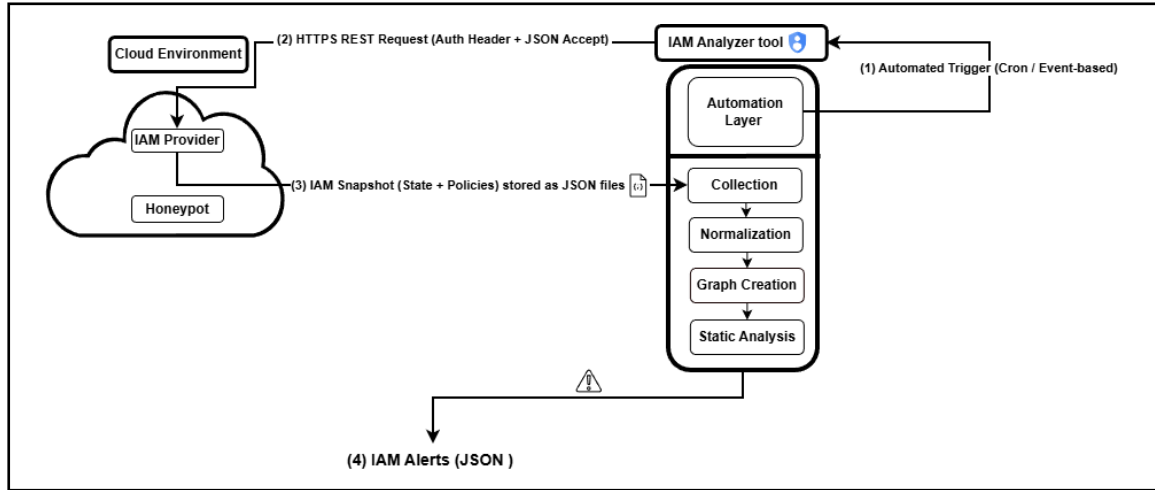
الفصل الثالث

الحل المقترح

3 الفصل الثالث - الحل المقترح

يقدم هذا الفصل وصفاً تفصيلياً للحل المقترح من حيث التصميم والتنفيذ، حيث يركّز على تحليل سياسات إدارة الهوية والصلاحيات (IAM Analyzer) ودمجها مع مصيدة أمنية (Honeypot) ضمن بيئة حوسبة سحابية من نمط البنية التحتية كخدمة (IaaS). يهدف هذا الحل إلى دراسة بنية الصلاحيات واكتشاف أخطاء الضبط التي قد تؤدي إلى تصعيد الصلاحيات.

يعتمد الحل المقترح على تكامل منظّم بين مكونات التحليل البنيوي والسلوكي ضمن بيئة حوسبة سحابية موحّدة. يوضّح الشكل (1-3) المخطّط المعماري العام للحل المقترح، مبيناً توزّع المكونات الرئيسية، والعلاقات فيما بينها، وتدقّق البيانات والأحداث الأمنية ضمن إطار التحليل المعتمد.



الشكل 1-3 المخطّط المعماري العام للنظام

تم تنفيذ جميع المكونات ضمن جهاز افتراضي واحد يعمل باستخدام VMware على نظام التشغيل Ubuntu 20.04.6. تعمل المنصة السحابية (MicroStack) داخل هذا الجهاز الافتراضي لتوفير بيئة حوسبة سحابية من نمط IaaS، وتضم خدمات OpenStack الأساسية، وعلى رأسها خدمة إدارة الهوية والصلاحيات (Keystone)، إضافة إلى موارد سحابية فعلية مثل المصيدة الأمنية (Honeypot) التي يتم نشرها كآلة افتراضية داخل المنصة. في المقابل، تعمل أداة IAM Analyzer خارج المنصة السحابية من الناحية المنطقية، حيث تُنفَّذ كأداة تحليل مستقلة مكتوبة بلغة Python على مستوى نظام التشغيل المضيف، وتتفاعل مع المنصة السحابية فقط عبر واجهات OpenStack البرمجية (APIs)، دون أن تكون جزءاً من خدمات OpenStack نفسها.

وكما هو موضّح في الشكل السابق، يتم تشغيل أداة IAM Analyzer تلقائياً عبر آلية مجدولة أو اعتماداً على أحداث محددة. تقوم الأداة بإرسال طلبات مصادقة إلى خدمة IAM داخل المنصة السحابية لاستخراج

Snapshot عن حالة إدارة الهوية والصلاحيات والسياسات المطبقة. تُخزّن بصيغة JSON، ثم تُحلّل داخل الأداة، وفي حال اكتشاف أنماط ضبط غير آمن، يتم توليد مخرجات وتحذيرات تحليلية بصيغة JSON، في حين تُستخدم المصيدة الأمنية مستقبلاً لرصد السلوك الفعلي للحسابات من خلال التفاعل مع خدمات خاضعة للمراقبة، مما يتيح فهماً أعمق للعلاقة بين أخطاء الصلاحيات والأهداف التي يسعى المهاجمون للوصول إليها.

3.1 بيئة العمل السحابية

يستعرض هذا القسم المنصة السحابية المعتمدة من حيث دورها ووحداتها الأساسية وفوائدها كبيئة قابلة للتحكّم والعزل، تمهيداً لعرض آلية تنفيذ الحل المقترح ضمن بيئة سحابية افتراضية.

3.1.1 منصة Openstack

تُعدّ OpenStack منصّة حوسبة سحابيّة مفتوحة المصدر تُستخدم لبناء وإدارة بيئات الحوسبة السحابيّة العامّة والخاصّة، وتوفّر إمكانيّات متقدّمة لتقديم خدمات البنية التحتيّة كخدمة (Infrastructure as a Service – IaaS). تعتمد المنصّة على مجموعة من الخدمات المترابطة التي تُمكن من إدارة الموارد الافتراضيّة، بما يشمل موارد الحوسبة، والشبكات، والتخزين، إضافةً إلى خدمات إدارة الهوية والصلاحيّات.

استُخدمت OpenStack كقاعدة تقنيّة لبناء البيئة السحابيّة المستضيفّة لمكوّنات النظام الأمني، مثل أداة تحليل سياسات إدارة الهوية والصلاحيّات (IAM Analyzer) والمصيدة الأمنيّة (Honeypot)، حيث توفّر بيئةً قابلةً للتوسّع والتحكّم، بما يسمح بمحاكاة سيناريوهات واقعيّة لسلوك المستخدمين ضمن بنية سحابيّة معزولة وأمنة.

3.1.1.1 المكونات الأساسية في OpenStack

تتكوّن منصّة OpenStack من مجموعة من الوحدات الأساسيّة التي تعمل معاً ضمن بنية متكاملة لإدارة موارد الحوسبة السحابيّة، ومن أبرز هذه الوحدات:

- Nova: مسؤولة عن إدارة موارد الحوسبة، وإنشاء وتشغيل الأجهزة الافتراضيّة.
- Neutron: تُستخدم لإدارة الشبكات الافتراضيّة، والتحكّم في آليات الاتصال بين الأجهزة والخدمات.
- Keystone: تُعنى بإدارة الهوية، والمصادقة، والصلاحيّات، وتمثّل الأساس المفاهيمي لنظام إدارة الهوية والصلاحيّات (IAM).
- Glance: توفّر خدمة إدارة صور الأنظمة الافتراضيّة المستخدمة في إنشاء الأجهزة.
- Horizon: واجهة رسوميّة تفاعليّة تتيح إدارة موارد OpenStack ومكوّناتها بشكل مركزي.

تساهم هذه الوحدات في تحقيق فصلٍ واضحٍ بين مكوّنات النظام من خلال تشغيلها ضمن أجهزة افتراضيّة مستقلّة، ممّا يعزّز مبدأ العزل، ويزيد من مستوى التحكّم والأمان داخل البيئة السحابيّة.

3.1.1.2 فوائد استخدام OpenStack

يُتيح استخدام OpenStack التحكم الكامل في البنية التحتية السحابية دون الاعتماد على مزودي خدمات سحابية خارجيين، مما يسمح بإنشاء بيئة افتراضية معزولة ومُدارة ذاتياً. يوفّر ذلك إمكانية تخصيص موارد مستقلة لكل مكون من مكونات النظام الأمني، وتشغيلها ضمن بنية سحابية تحاكي بيئات التشغيل الحقيقية.

تُمكن هذه البيئة من اختبار سياسات إدارة الهوية والصلاحيات وتحليل نتائج الضبط غير الصحيح للصلاحيات، من خلال مراقبة سلوك الحسابات داخل النظام وتأثير ذلك على مستوى العزل والأمان، وهو ما يوضّح عملياً دور نماذج البنية التحتية كخدمة (IaaS) في دعم تحليل التهديدات الأمنية.

3.1.1.3 كفاءة اختبار سحابية OpenStack

استُخدمت منصة OpenStack كبيئة اختبار سحابية مُتحمّك بها لدراسة السلوك الأمني ضمن بنية تحتية افتراضية. يتيح هذا الإعداد نشر مكونات النظام ضمن أجهزة افتراضية مستقلة، بما يسمح بتحليل التفاعل بين الحسابات والخدمات في سياق سياسات إدارة الهوية والصلاحيات.

يركّز هذا الاستخدام على مراقبة تأثير الضبط غير الصحيح للصلاحيات وسلوك الحسابات داخل البيئة السحابية، ضمن نطاق معزول لا يؤثر على أنظمة تشغيلية فعلية، الأمر الذي يوفّر أساساً منهجياً مناسباً للتحليل والتقييم الأمني قبل الانتقال إلى بيئات إنتاج حقيقية.

3.1.2 منصة MicroStack

تُعدّ MicroStack توزيعاً خفيفاً لمنصة OpenStack، طُوّر من قبل شركة Canonical، ويهدف إلى تشغيل بيئة حوسبة سحابية متكاملة على جهاز واحد. يوفّر هذا التوزيع مجموعة من خدمات OpenStack الأساسية ضمن إعداد مبسّط، مما يجعله مناسباً للاستخدام في البيئات التجريبية والتعليمية التي تتطلب موارد محدودة وبنية تشغيلية غير معقّدة.

تم اعتماد MicroStack لتوفير بيئة بنية تحتية كخدمة (IaaS) مصغّرة تُستخدم في نشر وتشغيل مكونات النظام الأمني، مع الحفاظ على الخصائص الأساسية للبيئات السحابية من حيث العزل، وإدارة الموارد، وسهولة التحكم.

3.1.2.1 المكونات المستخدمة ضمن MicroStack

يتضمّن MicroStack مجموعة من خدمات OpenStack الأساسية التي تلبي متطلبات البيئة التجريبية، ومن أبرزها:

- Nova
- Keystone
- Neutron
- Glance
- Horizon

تُثبت هذه المكونات وتُهيأ تلقائياً ضمن MicroStack، مما يسهل إعداد البيئة السحابية والبدء بتنفيذ التجارب الأمنية دون الحاجة إلى خطوات نشر معقدة.

3.1.3 الفرق بين OpenStack و Microstack

يوضح الجدول (1-3) الفروقات الجوهرية بين منصة OpenStack وتوزيع MicroStack من حيث الهدف، وبنية النشر، ومتطلبات الموارد، وحالات الاستخدام.

جدول 1-3 مقارنة بين OpenStack و MicroStack

المعيار	OpenStack	Microstack
الهدف	بيئات إنتاجية واسعة النطاق	بيئات اختبار وتطوير صغيرة
عدد العقد	يدعم عدة عقد (Multi-node)	عقدة واحدة فقط (Single-node)
التثبيت والإعداد	إعداد معقد ويتطلب إدارة متقدمة	إعداد مبسط باستخدام واجهة أوامر موحدة
استهلاك الموارد	مرتفع نسبياً	منخفض نسبياً
حالات الاستخدام	الشركات ومراكز البيانات	البيئات التعليمية والتجريبية

تُعدّ OpenStack منصة متكاملة لبناء وإدارة البنى التحتية السحابية واسعة النطاق، في حين يُمثل MicroStack توزيعاً خفيفاً يُستخدم لتشغيل OpenStack ضمن بيئات محدودة الموارد. وبناءً على ذلك، تم اعتماد MicroStack كبيئة تنفيذ عملي تتيح الاستفادة من الخصائص الأساسية لـ OpenStack، مع تجنب التعقيدات التشغيلية المرتبطة بإدارته في البيئات الإنتاجية واسعة النطاق.

3.2 أداة تحليل إدارة الهوية والصلاحيات (IAM Analyzer)

تمثل أداة IAM Analyzer المكوّن التحليلي الأساسي في الحل المقترح، حيث جرى تصميمها لدراسة بنية إدارة الهوية والصلاحيات داخل البيئة السحابية، بهدف الكشف عن حالات الضبط غير الصحيح للصلاحيات والأنماط ذات المخاطر الأمنية. تعتمد الأداة على تسلسلٍ منهجي يتكوّن من أربع مراحل رئيسية مترابطة، تبدأ بجمع البيانات، ثم تهيئتها ومعالجتها، يلي ذلك تمثيل العلاقات باستخدام الرسوم البيانية (Graph)، وصولاً إلى تطبيق مجموعة من القواعد الساكنة (Static Rules).

توفّر الأداة أساساً تقنياً واضحاً لاكتشاف حالات الضبط غير الآمن والانحرافات عن مبدأ أقلّ صلاحية، إضافة إلى دعم تفسير النتائج الأمنية الناتجة عن عملية التحليل.

3.2.1 مرحلة التجميع (Collection Phase)

تركّز مرحلة التجميع على استخراج الحالة الفعلية لإدارة الهوية والصلاحيات كما هي مطبقة أثناء تشغيل البيئة السحابية، دون إجراء أي تعديل أو تفسير للبيانات، وبما يتوافق مع مبدأ التحليل الساكن (Static)

(Analysis). تهدف هذه المرحلة إلى بناء لقطة شاملة (Snapshot) تمثل البنية الحقيقية للصلاحيات داخل النظام، وتشمل كيانات الهوية، علاقات التفويض، وسياسات التحكم بالوصول. وتُعد هذه المرحلة الأساس الذي تُبنى عليه جميع مراحل التحليل اللاحقة، إذ تعتمد دقة النتائج النهائية بشكل مباشر على اكتمال البيانات التي تم تجميعها وصحتها.

تم تنفيذ عملية الجمع بالاعتماد على واجهات OpenStack البرمجية الرسمية (OpenStack APIs)، مع التركيز الأساسي على خدمة Keystone باعتبارها المزود المركزي لإدارة الهوية والتحكم بالوصول ضمن منظومة OpenStack. تعتمد الأداة على إنشاء اتصال باستخدام بيانات الاعتماد الخاصة بالبيئة السحابية، والتي يتم تحميلها مباشرة من ملف الإعدادات microstack.rc، مما يضمن أن البيانات المستخرجة تعكس الحالة التشغيلية الفعلية للنظام دون التأثير على إعدادات الخدمات أو استقرارها.

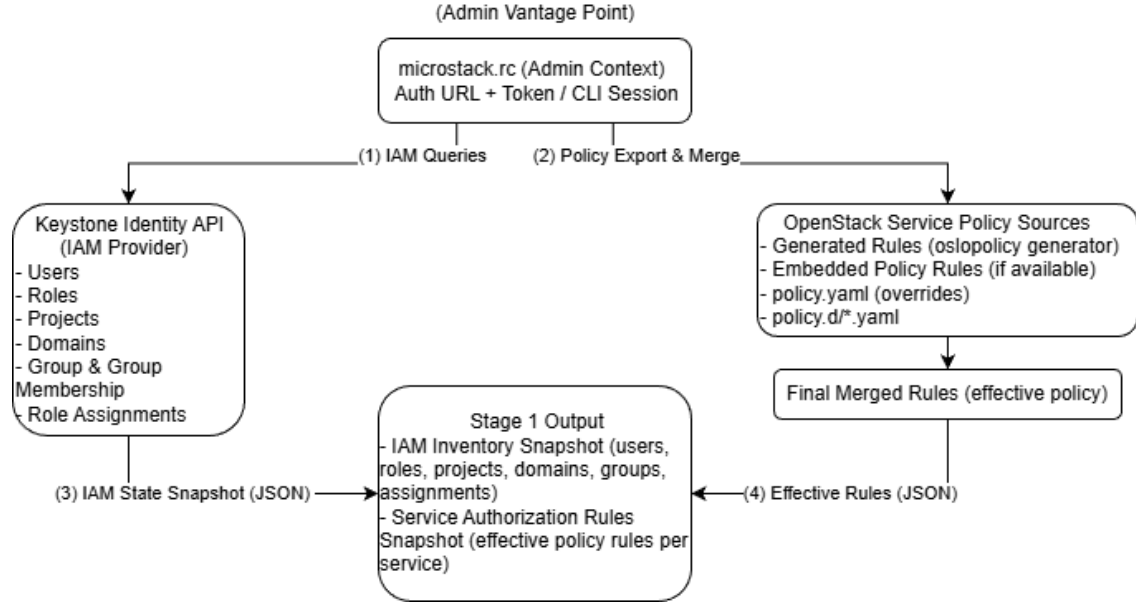
تشمل البيانات المستخرجة من Keystone جميع مكونات إدارة الهوية والصلاحيات، وتتضمن معلومات المستخدمين (Users)، المشاريع (Projects)، المجالات (Domains)، الأدوار (Roles)، والمجموعات (Groups)، إضافة إلى علاقات إسناد الأدوار (Role Assignments) التي توضح كيفية منح الأدوار للمستخدمين أو المجموعات ضمن نطاقات مختلفة، سواء على مستوى النظام (System Scope)، أو المشاريع (Project Scope)، أو المجالات (Domain Scope). كما يتم جمع بيانات عضوية المجموعات (Group Memberships) بشكل صريح، نظراً لدورها في منح الصلاحيات بشكل غير مباشر داخل البيئات السحابية.

ولتعزيز سياق البيانات المُجمَّعة وإتاحة إمكانية تتبعها لاحقاً، يتم إرفاق معلومات وصفية (Metadata) بعملية الجمع، مثل وقت التنفيذ. يساهم ذلك في ربط النتائج بسياقها الزمني، ويتيح مقارنة لقطات مختلفة (Snapshots) للنظام عند الحاجة.

وبالتوازي مع جمع بيانات الهوية، تشمل مرحلة التجميع استخراج سياسات التحكم بالوصول الخاصة بخدمات OpenStack المختلفة مثل Nova و Neutron و Glance. تعتمد عملية جمع السياسات على آليتين متكاملتين: الأولى استخراج السياسات المضمنة ضمن الشيفرة المصدرية للخدمات (Policy-in-Code) باستخدام أدوات OpenStack الرسمية، والثانية قراءة ملفات السياسات الفعلية المعروفة ضمن بيئة (MicroStack (policy.yaml / policy.json / policy.d. يضمن هذا الدمج الحصول على السياسة الفعالة (Effective Policy) التي تعتمد عليها الخدمات أثناء التشغيل، وليس فقط القيم الافتراضية.

ناتج مرحلة التجميع هو مجموعة بيانات خام (Raw Snapshot) محفوظة بصيغة JSON، تمثل الحالة الفعلية لإدارة الهوية والصلاحيات وسياسات التفويض في البيئة السحابية في لحظة زمنية محددة. يتم تمرير هذه البيانات كما هي إلى مرحلة التهيئة والمعالجة اللاحقة دون إجراء أي تعديل عليها، بما يضمن الفصل الواضح بين منطق الجمع ومنطق التحليل ويحافظ على سلامة البيانات الأصلية.

يوضح الشكل (2-3) المخطط المعماري لمرحلة التجميع، حيث يبين مصادر بيانات إدارة الهوية والصلاحيات داخل البيئة السحابية، وآلية تفاعل أداة IAM Analyzer مع خدمة Keystone، إضافة إلى مسار استخراج سياسات التفويض من مصادرها المختلفة، وتوحيدها ضمن لقطة حالة واحدة تُستخدم كنقطة انطلاق للمراحل التحليلية اللاحقة.



الشكل 2-3 مرحلة التجميع (Collection Phase)

3.2.2 مرحلة التهيئة والمعالجة المبدئية (Normalization Phase)

تهدف مرحلة التهيئة والمعالجة المبدئية إلى تنظيم البيانات الخام الناتجة عن مرحلة التجميع وتوحيد صيغ تمثيلها، بحيث يتم تحويلها من بنية غير متجانسة إلى نموذج منطقي موحد وقابل للتحليل اللاحق. تقتصر هذه المرحلة على إعادة هيكلة البيانات وربط الكيانات ذات العلاقة، دون إجراء أي استنتاجات أو تقييمات أمنية، وذلك تمهيداً لاستخدامها في مراحل التحليل وبناء الرسوم البيانية. بعد الانتهاء من مرحلة جمع البيانات من خدمة Keystone وخدمات OpenStack المرتبطة، يتم تمرير المخرجات الخام بصيغة JSON إلى مرحلة التطبيق. تركز هذه المرحلة على إعادة تنظيم بيانات الهوية والصلاحيات بحيث تصبح العلاقات بين المستخدمين، الأدوار، ونطاقات الصلاحيات (Scopes) واضحة، مع الحفاظ على مصدر منح الصلاحية (Provenance) لضمان قابلية تفسير النتائج لاحقاً عند توليد التنبيهات الأمنية.

تبدأ عملية التهيئة ببناء Base Maps تعتمد على معرفات الكيانات (IDs) كمفاتيح أساسية، وتشمل خرائط المستخدمين (Users)، المشاريع (Projects)، الأدوار (Roles)، المجموعات (Groups)، والمجالات (Domains) عند توفرها. يتم في هذه الخطوة توحيد الحقول الأساسية لكل كيان (مثل id، name،

(domain_id)، مع تجاهل السجلات غير المكتملة أو التي تفتقد معرفاً صالحاً، مما يعزز موثوقية البيانات قبل الانتقال إلى مراحل التحليل اللاحقة.

بعد ذلك، يتم ربط المستخدمين بعضويتهم في المجموعات استناداً إلى بيانات عضوية المجموعات (Group Memberships) المستخرجة من Keystone. تُحوّل هذه البيانات إلى بنية مباشرة على مستوى المستخدم، بحيث يصبح لكل مستخدم تمثيل صريح للمجموعات التي ينتمي إليها. تُعد هذه الخطوة محورية نظراً لأن منح الصلاحيات في البيئات السحابية يتم في كثير من الأحيان بشكل غير مباشر عبر المجموعات، وهو ما يؤثر مباشرة على تفسير حالات تداخل الصلاحيات أو تصعيدها.

تمثل معالجة إسنادات الأدوار (Role Assignments) المرحلة الأكثر أهمية ضمن عملية التهيئة، حيث يتم تحويلها إلى تمثيل موحد وفق نطاق الصلاحية المعتمد. تعتمد Keystone ثلاثة نطاقات رئيسية لمنح الأدوار:

- نطاق النظام (System Scope)
- نطاق المشروع (Project Scope)
- نطاق المجال (Domain Scope)

تقوم الأداة بتحليل كل عملية إسناد دور وتحديد نوع النطاق المرتبط بها، ثم تمثيلها ضمن بنية المستخدم وفق النطاق المناسب. ولضمان الدقة وقابلية التفسير، لا يتم تخزين اسم الدور فقط، بل يتم حفظ الدور مع مصدر منحه (Provenance) على مستوى كل دور بشكل مستقل، بحيث يوضح ما إذا كان الدور قد مُنح بشكل مباشر للمستخدم أو عبر مجموعة.

وبالنظر إلى أن Keystone تسمح بإسناد الأدوار للمجموعات أيضاً، يتم التعامل مع هذا النوع من الإسناد على مرحلتين متتاليتين. في المرحلة الأولى، يتم تسجيل إسنادات الأدوار الخاصة بالمجموعات ضمن مخزن مؤقت دون توسيعها فوراً. في المرحلة الثانية، يتم توسيع هذه الإسنادات عبر بيانات عضوية المجموعات وربط الدور بكل مستخدم عضو في المجموعة، مع توثيق أن مصدر المنح هو مجموعة وليس إسناداً مباشراً. يتيح هذا الأسلوب فصل منطق اكتشاف الإسنادات عن منطق توسيعها، مما يجعل مرحلة التهيئة أكثر وضوحاً وأسهل للتحقق.

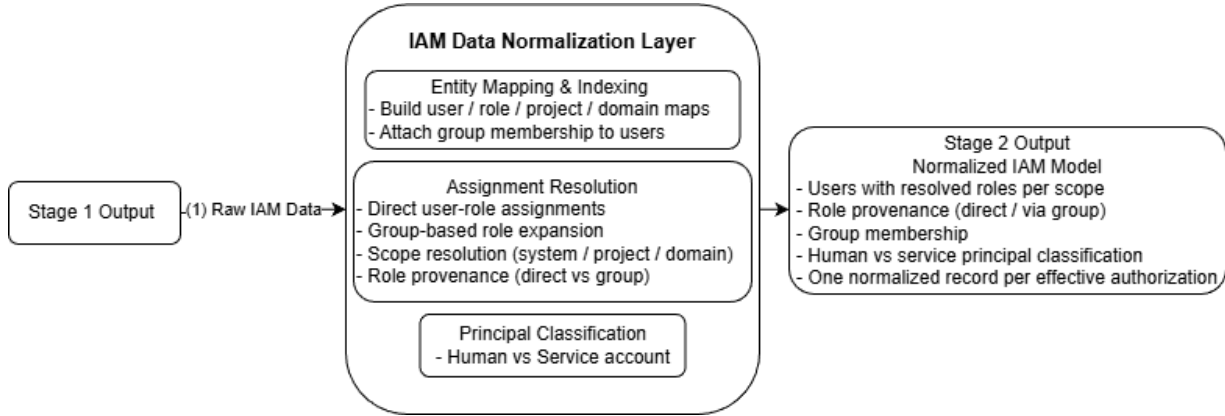
بعد إتمام ربط الأدوار، يتم تنفيذ عمليات تنظيف تشمل إزالة التكرار وترتيب القوائم لضمان اتساق المخرجات. تتم إزالة التكرارات باستخدام مفتاح مركب يجمع بين اسم الدور، نوع مصدر المنح، ومعرّف المجموعة عند وجوده، مما يمنع تضخيم البيانات دون فقدان المعلومات الدلالية. كما يتم ترتيب القوائم بهدف تسهيل المقارنة بين لقطات مختلفة للنظام ودعم عمليات الاختبار والتحقق.

في الخطوة الأخيرة من مرحلة التهيئة، يتم تصنيف الكيانات إلى مستخدمين بشريين (Human Users) وحسابات خدمات (Service Principals) باستخدام قواعد استدلالية (Heuristic Rules) غير معتمدة على تقنيات تعلم الآلة. تعتمد هذه القواعد على أنماط التسمية الشائعة لحسابات الخدمات، وعلى مطابقة أسماء المستخدمين مع أسماء الخدمات المعروفة في OpenStack، إضافة إلى معلومات مستخرجة من

سجل الخدمات (Service Catalog). ينتج عن ذلك حقل توصيفي يحدّد طبيعة كل كيان، ويُستخدم لاحقاً لتصفية الضوضاء الناتجة عن حسابات الخدمات والتركيز على مسارات التصعيد المرتبطة بالمستخدمين البشريين.

ناتج مرحلة التهيئة هو نموذج IAM موحد محفوظ بصيغة JSON، يمثّل صورة دقيقة لعلاقات الهوية والصلاحيات في البيئة السحابية، مع الحفاظ على مصدر منح الصلاحيات على مستوى كل دور. يوفّر هذا النموذج أساساً لبناء الرسوم البيانية وتطبيق قواعد التحليل الساكن في المراحل اللاحقة.

يوضّح الشكل (3-3) المخطّط المعماري لمرحلة التهيئة والمعالجة المبدئية، حيث يبيّن انتقال البيانات من اللقطة الخام الناتجة عن مرحلة التجميع إلى نموذج IAM موحد، مع توضيح مراحل الربط، التوسيع، التصنيف، والمخرجات النهائية المستخدمة في التحليل.



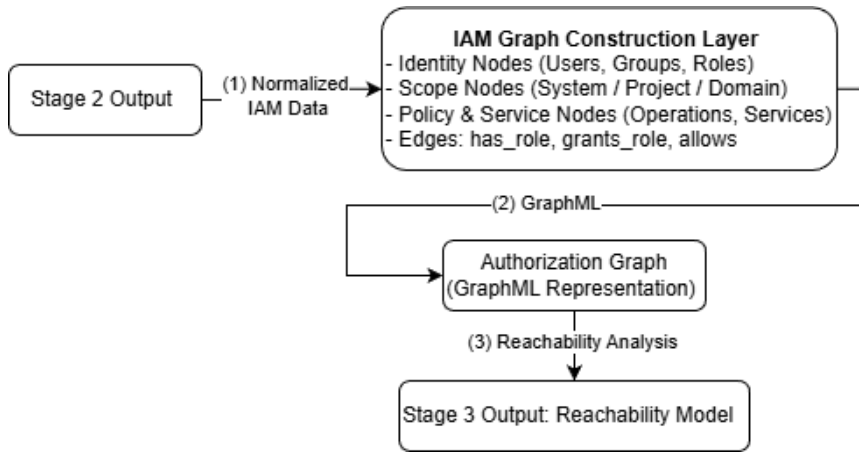
الشكل 2-3 مرحلة التهيئة والمعالجة المبدئية لبيانات IAM

3.2.3 مرحلة بناء الرسم البياني (Graph Construction Phase)

في هذه المرحلة، يتم تحويل بيانات إدارة الهوية والصلاحيات، بعد توحيدها ومعالجتها في مرحلة التهيئة (Normalization)، إلى نموذج رسم بياني (Graph) يعبر بشكل منهجي وقابل للتحليل عن العلاقات البنوية داخل نظام إدارة الهوية والصلاحيات (IAM).

يهدف هذا النموذج إلى تمكين التحليل البنوي للصلاحيات، ودعم تتبّع مسارات التفويض، والكشف عن علاقات الوصول غير المباشرة التي قد لا تكون ظاهرة في التمثيلات التقليدية القائمة على القوائم أو الجداول.

يوضّح الشكل (3-3) البنية المعمارية لمرحلة بناء الرسم البياني، حيث يتم تحويل نموذج IAM الموحد إلى رسم بياني رسمي، ومن ثم إجراء تحليل الوصول (Reachability Analysis) لاستخلاص العلاقات الفعلية بين الأدوار (Roles) والعمليات المسموح بها (Operations). ويُستخدم ناتج هذه المرحلة لاحقاً كمدخل أساسي لتطبيق القواعد الساكنة وتقييم المخاطر الأمنية.



الشكل 3-3 مرحلة بناء الرسم البياني

3.2.3.1 طبقة الهوية والتفويض (Identity & Authorization Layer)

يبدأ بناء الرسم البياني من طبقة الهوية، حيث يتم تمثيل الكيانات الأساسية لنظام IAM كنقاط (Nodes)، وتشمل المستخدمين (Users)، المجموعات (Groups)، والأدوار (Roles). يتم إنشاء علاقات العضوية بين المستخدمين والمجموعات، ثم ربط المستخدمين أو المجموعات بالأدوار الممنوحة لهم.

يتم تمثيل الأدوار كنقاط مستقلة مرتبطة صراحةً بنطاق الصلاحية الخاص بها (System / Project / Domain)، بحيث لا يُنظر إلى الدور كصلاحية مطلقة، بل كصلاحية صالحة فقط ضمن نطاق محدد. يتيح هذا التمثيل الحفاظ على الدلالة الدقيقة لنموذج التفويض المعتمد في Keystone.

كما يتم الاحتفاظ بمعلومة مصدر منح الدور (Role Provenance)، سواء كان الإسناد مباشراً للمستخدم أو موروثاً عبر مجموعة. ويُترجم ذلك في الرسم البياني من خلال علاقات تفويض واضحة، مما يسمح لاحقاً بتتبع مسارات التفويض غير المباشر وتحليل مخاطر الانتساع غير المقصود للصلاحيات.

3.2.3.2 طبقة سياسات التحكم بالوصول (Policy Layer)

في طبقة السياسات، يتم تمثيل كل عملية تحكم بالوصول (Policy Operation) كنقطة مستقلة مرتبطة بالخدمة السحابية التي تنتمي إليها. تعتمد عملية الربط بين الأدوار والعمليات على تحليل قواعد السياسات الفعلية بعد توسيع المراجع غير المباشرة من نوع <rule:alias>، بما يضمن الكشف الكامل عن الأدوار المشار إليها فعلياً داخل منطق السياسة.

لا يتم في هذه المرحلة اتخاذ أي قرار أمني أو تصنيفي، بل يُحافظ على تمثيل محايد يربط:

- الأدوار بالعمليات التي تسمح بها السياسات
- والعمليات بالخدمات السحابية التي تنفذها

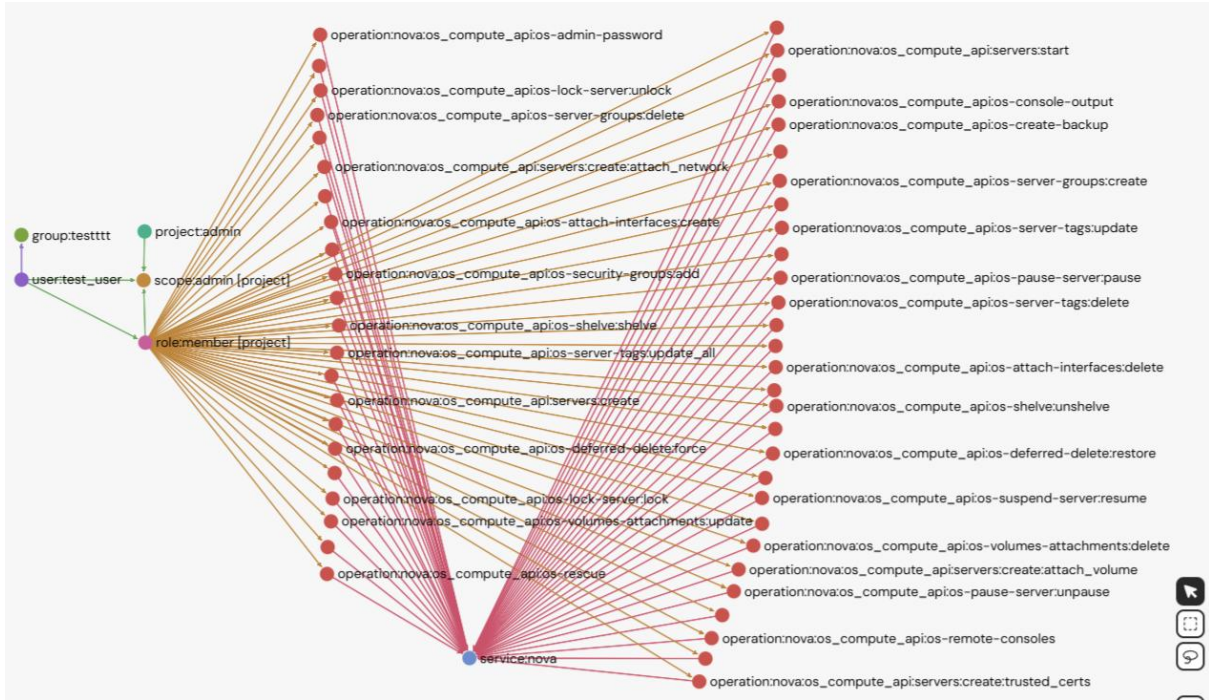
يُستخدم هذا التمثيل كأساس لإجراء تحليل الوصول (Reachability Analysis) دون الحاجة إلى تنفيذ السياسات تشغيلياً أو محاكاة سلوك النظام، مما يتماشى مع منهجية التحليل الساكن المعتمدة في الحل المقترح.

3.2.3.3 خصائص نموذج الرسم البياني

يتميّز النموذج الرسومي الناتج بالخصائص التالية:

- تمثيل واضح ومنفصل لطبقة الهوية وطبقة السياسات.
- الحفاظ الصارم على مفهوم النطاق (Scope) في جميع علاقات الصلاحيات.
- توثيق مصدر منح الصلاحيات (مباشر أو عبر مجموعة) بشكل قابل للتتبع.
- حيادية النموذج، حيث لا يتم إطلاق أي تنبيهات أمنية في هذه المرحلة.

تم تصدير الرسم البياني بصيغة GraphML، مما يتيح تحليله بصرياً باستخدام أدوات تحليل الرسوم البيانية مثل Gephi إذ يوضّح الشكل (3-4) مثلاً تمثيلياً للرسم البياني الناتج عن هذه المرحلة، حيث تُعرض العلاقات بين كيانات الهوية، النطاقات، الأدوار، عمليات التحكم بالوصول، والخدمات المرتبطة بها، باستخدام أداة Gephi، وذلك بهدف إظهار البنية الداخلية للنموذج الرسومي والعلاقات المكوّنة له.



الشكل 3-4 الرسم البياني للعلاقات

3.2.3.4 تحليل الوصول (Reachability Analysis)

بعد تصدير الرسم البياني، يتم تنفيذ تحليل الوصول لاستخلاص العلاقات الفعلية بين الأدوار والعمليات (Role → Operation). يهدف هذا التحليل إلى تحويل سياسات التحكم بالوصول المعرّفة نظرياً إلى نموذج قابل للقياس يوضح ما الذي يمكن لكل دور تنفيذه فعلياً ضمن نطاقاته المختلفة.

يمثل ناتج هذه المرحلة نموذج الوصول (Reachability Model)، والذي يُستخدم لاحقاً كأساس لتطبيق القواعد الساكنة واكتشاف حالات الصلاحيات المفرطة ومسارات التفويض ذات المخاطر المحتملة.

3.2.4 مرحلة القواعد الساكنة (Static Rules Phase)

تمثل مرحلة القواعد الساكنة المرحلة التحليلية الأهم ضمن مسار العمل المعتمد في النظام المقترح، إذ تشكل نقطة الانتقال من التمثيل البنيوي لنظام إدارة الهوية والصلاحيات إلى استخلاص مؤشرات أمنية قابلة للتفسير. تعتمد هذه المرحلة على تطبيق مجموعة محدودة ومدرسة من القواعد الأمنية الساكنة (Static Rules) على نموذج الرسم البياني وناتج تحليل الوصول (Reachability Model)، بهدف الكشف عن أنماط ضبط غير آمن للصلاحيات دون الاعتماد على بيانات تشغيلية أو سلوكية.

تستند هذه المرحلة إلى مبدأ أساسي مفاده أن العديد من مخاطر تصعيد الصلاحيات في البيئات السحابية يمكن اكتشافها من خلال تحليل بنية التفويض نفسها، حتى في غياب أي نشاط هجومي فعلي. ويجعل ذلك هذا النهج مناسباً للتحليل الاستباقي ضمن بيئات البنية التحتية كخدمة (IaaS)، حيث لا تتوفر دائماً بيانات سلوكية أو سجلات تشغيلية متقدمة.

3.2.4.1 مدخلات مرحلة القواعد الساكنة

تعتمد مرحلة القواعد الساكنة على مخرجات المراحل السابقة دون إجراء أي عمليات جمع إضافية للبيانات. وتشمل المدخلات الأساسية:

- نموذج الرسم البياني الموجّه (GraphML) الذي يمثل العلاقات البنيوية بين المستخدمين، الأدوار، النطاقات، والسياسات.
- ناتج تحليل الوصول (Reachability Model) الذي يربط كل دور بمجموعة العمليات التي يمكنه تنفيذها فعلياً.
- معلومات مصدر منح الصلاحيات (Provenance) التي توضح ما إذا كانت الصلاحية مُنحت مباشرة أو عبر مجموعة.
- خصائص النطاق (System / Project / Domain) المرتبطة بكل دور.

3.2.4.2 منهجية تصميم القواعد الساكنة

تم تصميم القواعد الساكنة وفق منهجية انتقائية صارمة، تأخذ بعين الاعتبار قابلية التحقق الساكن (Static Verifiability) والملاءمة المعمارية لبيئة MicroStack. لا تهدف هذه القواعد إلى تغطية جميع الضوابط الواردة في أطر العمل القياسية مثل NIST و CIS، بل تركز على الضوابط التي يمكن تمثيلها واكتشافها مباشرة من خلال بنية IAM ونموذج التفويض.

تعتمد كل قاعدة على نمط بنيوي (Structural Pattern) محدد داخل الرسم البياني، مثل:

- منح صلاحيات مفرطة (Excessive Privileges).
- أدوار ذات نطاق نظامي (System Scope) ممنوحة لمستخدمين بشريين.

- صلاحيات عالية تم توريثها عبر مجموعات دون تخصيص صريح.
- مسارات وصول غير مباشرة تؤدي إلى عمليات إدارية حرجية.

يضمن هذا الأسلوب أن تكون نتائج التحليل قائمة على أدلة بنوية واضحة وقابلة للتفسير، دون اللجوء إلى افتراضات احتمالية أو تحليل سلوكي.

3.2.4.3 الارتباط بالمعايير القياسية

تم اشتقاق القواعد الساكنة المعتمدة بالاستناد إلى ضوابط مختارة من أطر العمل القياسية المعترف بها، وعلى رأسها معيار NIST SP 800-53 (Rev.5) و CIS Benchmarks، وبخاصة الضوابط المرتبطة بالتحكم بالوصول ومبدأ أقل صلاحية (Least Privilege).

يوضح الجدول (1-3) التصنيفات الأساسية للقواعد الساكنة (*T) المطبقة، مع ربط كل فئة بالضابط القياسي الموافق لها ومصدر الاشتقاق.

جدول 1-3 القواعد الساكنة المطبقة

الضابط القياسي	مصدر الاشتقاق القياسي	مثال على القاعدة	فئة القاعدة (Taxonomy)
AC-6 (Least Privilege)	NIST SP 800-53r5	Human user has admin at system scope	T1 – Excessive Privilege
AC-5, AC-6	NIST SP 800-53r5	Privileged role granted via group	T2 – Privileged Role Exposure
enforce_scope	OpenStack Oslo Policy	Project role reaches system-only operation	T3 – Scope Violation
enforce_new_defaults	OpenStack Oslo Policy	Operation uses is_admin semantic	T4 – Policy Semantic Weakness
AC-2, AC-6	NIST SP 800-53r5	Non-admin reaches identity:create_user	T5 – Dangerous Operation Reachability
AC-2, AC-6	NIST SP 800-53r5	Service principal has admin role	T6 – Service Principal Hygiene
CIS 2.15	CIS Benchmarks (Conceptual)	Policy contains wildcard token	T8 – Over-broad Policy
Identity	OpenStack Security Guide	Non-system role reaches system admin ops	T9 – Admin Surface Exposure
enforce_scope	Oslo Policy	Project admin reaches system operation	T10 – Cross-scope Exposure

بالإضافة إلى ذلك، تم تضمين مجموعة قواعد موسّعة موسومة بـ (X*) بهدف توسيع التغطية نحو عمليات IaaS عالية التأثير ضمن خدمات OpenStack المختلفة، وتُعرض هذه القواعد في الجدول (2-3) بوصفها امتداداً تطبيقياً للتغطية.

جدول 2-3 القواعد الموسّعة

أمثلة على نطاق التغطية	الهدف العام	فئة القاعدة (Taxonomy)
policy, implied_role, create_project, create_domain	تغطية عمليات عالية التأثير مرتبطة بإدارة الهوية والصلاحيات، وتشمل إدارة السياسات، الأدوار، المشاريع، و Domains ضمن خدمة Keystone	X1 – Keystone High-impact Coverage
aggregates, os-aggregates	تغطية عمليات التحكم بالبنية التحتية للحوسبة، وخصوصاً العمليات التي تؤثر على المضيفين الفيزيائيين (Hosts) وتجميع الموارد (Aggregates)	X2 – Nova Control Surface
quota, extension	تغطية العمليات الإدارية المتقدمة في خدمة الشبكات، مثل إدارة الحصص (Quotas) والإضافات (Extensions) التي تؤثر على سلوك الشبكة	X3 – Neutron Admin Extensions
types, qos	تغطية عمليات إدارة أنواع وحدات التخزين (Volume Types) وسياسات QoS (Quality of Service) وهي السياسات التي تتحكم بأداء الموارد مثل التخزين والخصائص التشغيلية	X4 – Cinder Types & QoS
image delete	تغطية العمليات الحساسة المرتبطة بإدارة صور الأنظمة الافتراضية، والتي قد تؤثر على توفر الموارد أو سلامتها	X5 – Glance Destructive Ops

وقد اقتصر تطبيق هذه المعايير على القواعد التي يمكن التحقق منها اعتماداً على الحالة الساكنة لإدارة الهوية والصلاحيات، دون الحاجة إلى بيانات تشغيلية مثل سجلات الدخول أو التحليل الزمني للأحداث. ويعود ذلك إلى أن عدداً كبيراً من الضوابط القياسية يتطلب مراقبة سلوكية مستمرة أو تكاملات تشغيلية (مثل SIEM)، وهو ما لا يتوفر افتراضياً ضمن هذا النطاق التطبيقي في بيئة MicroStack.

تُعد مرحلة القواعد الساكنة نقطة التحوّل الأساسية في النظام المقترح، إذ تنتقل فيها عملية التحليل من مستوى التمثيل البنوي لإدارة الهوية والصلاحيات إلى مستوى الاستدلال الأمني الموجّه. ومن خلال هذه المرحلة، يصبح بالإمكان ربط بنية التفويض النظرية بمخاطر أمنية محتملة بصورة استباقية، دون الحاجة إلى تنفيذ أي نشاط هجومي فعلي أو انتظار وقوع حادث أمني.

وبذلك، تمثل هذه المرحلة الأساس الذي يُبنى عليه أي توسّع مستقبلي للنظام، سواء من خلال إضافة قواعد ساكنة أكثر تقدماً، أو من خلال دمج التحليل البنوي مع آليات رصد سلوكي عند توقّر البنية التقنية الداعمة، بما يعزّز شمولية التحليل ودقّته في البيانات السحابية.

3.3 المصيدة الأمنية (Honeypot)

تُعد المصيدة الأمنية أحد المكونات الداعمة في النظام المقترح، حيث جرى تصميمها كبيئة معزولة وخاضعة للضبط، تهدف إلى رصد السلوكيات غير المتوقعة أو المشبوهة داخل البيئة السحابية دون تعريض الخدمات التشغيلية أو البيانات الحساسة لأي مخاطر.

تعتمد فكرة المصيدة على توفير خدمات تبدو حقيقية من منظور المستخدم أو المهاجم، بينما تعمل فعلياً كنقطة مراقبة لجمع الأدلة السلوكية المرتبطة بمحاولات الوصول أو التفاعل غير المصرّح به.

ولا يُنظر إلى المصيدة الأمنية في هذا السياق كعنصر مستقل بذاته، بل كجزء مكمل للتحليل البنيوي لإدارة الهوية والصلاحيات، بما يتيح الربط بين ما يُسمح به نظرياً من صلاحيات، وما يتم ممارسته فعلياً داخل البيئة السحابية.

3.3.1 تصميم بيئة المصيدة الأمنية ضمن MicroStack

تم تصميم بيئة المصيدة الأمنية ضمن بنية MicroStack بحيث تعمل داخل نطاق معزول منطقياً عن باقي مكونات النظام، من خلال فصلها على مستوى البنية الشبكية. يهدف هذا التصميم إلى ضمان عدم انتقال أي نشاط ضار محتمل إلى خدمات أخرى، مع الحفاظ على القدرة على مراقبة التفاعلات داخل المصيدة بشكل آمن.

يتيح هذا الفصل البنيوي استخدام المصيدة كبيئة اختبار سلوكي خاضعة للتحكم، دون التأثير على أداة تحليل إدارة الهوية والصلاحيات أو على استقرار المنصة السحابية نفسها.

3.3.2 إنشاء المصيدة الأمنية (Honeypot Deployment)

تم إنشاء المصيدة الأمنية ضمن بيئة MicroStack بهدف إدخال مكّون سلوكي تجريبي داخل البنية السحابية، يعمل كنقطة تفاعل خاضعة للمراقبة دون التأثير على مكونات التحليل البنيوي لإدارة الهوية والصلاحيات.

لا تهدف المصيدة في هذا السياق إلى منع الهجمات أو التصدي لها، بل إلى توفير بيئة تبدو قابلة للوصول، بما يسمح مستقبلاً بدراسة أنماط السلوك الناتجة عن استخدام الصلاحيات ضمن نطاق مسيطر عليه.

3.3.2.1 نشر خادم افتراضي مخصّص للمصيدة

تم نشر خادم افتراضي مخصّص للمصيدة باسم honeypot-vm باستخدام صورة نظام تشغيل خفيفة من نوع ubuntu-cloud، لملاءمتها لبيئات الاختبار وسهولة إدارتها.

تم اختيار مواصفات موارد متوازنة تتيح استقبال الاتصالات وتشغيل الخدمات الوهمية دون استهلاك مفرط لموارد البيئة السحابية.

3.3.2.2 إنشاء شبكة منطقية معزولة وربطها بالموجّه

لتحقيق العزل الشبكي، تم إنشاء شبكة افتراضية مخصصة للمصيدة داخل MicroStack وربطها بموجّه افتراضي مستقل. يتيح هذا التصميم التحكم بحركة المرور الواردة والصادرة، مع ضمان عدم انتقال أي نشاط من المصيدة إلى شبكات أو مشاريع أخرى داخل البيئة السحابية.

3.3.2.3 ضبط سياسة الوصول باستخدام مجموعات الأمن (Security Groups)

تم تعريف مجموعة أمن مخصصة وربطها بالخادم الافتراضي الخاص بالمصيدة، مع ضبط قواعد الوصول على النحو التالي:

- **Ingress:** السماح بالوصول إلى جميع المنافذ والخدمات الواردة، بهدف تعريض المصيدة بشكل مقصود وزيادة سطح التعريض (Attack Surface)، بما يتوافق مع فلسفة تصميم المصائد الأمنية.
- **Egress:** تم ضبط حركة المرور الصادرة بما يوازن بين المتطلبات التشغيلية الأساسية للخادم (مثل التحديثات أو الاتصالات الداخلية الضرورية) وبين تقليل المخاطر، بحيث لا تتحول المصيدة إلى نقطة انطلاق لأي نشاط خارج النطاق التجريبي أو إلى أداة غير مقصودة لإعادة توجيه الهجمات.

يعكس هذا الإعداد مبدأ التعريض المقصود تحت السيطرة (Controlled Exposure).

3.3.2.4 تهيئة آلية جمع الأدلة من السجلات

تم اعتماد جمع الأدلة بالاعتماد على السجلات النظامية المتاحة داخل بيئة MicroStack، دون دمج أنظمة مراقبة خارجية أو منصات SIEM.

تم التركيز بشكل خاص على سجلات خدمات إدارة الهوية مثل Keystone، باعتبارها المصدر الأساسي لتوثيق محاولات الوصول والتنبيهات المرتبطة بالسياسات. يتيح هذا الأسلوب:

- إنشاء أثر رقمي قابل للمراجعة (Audit Trail).
- ربط الأحداث السلوكية لاحقاً بنتائج التحليل البنيوي للصلاحيات.

3.3.3 تكامل المصيدة الأمنية مع أداة تحليل إدارة الهوية والصلاحيات

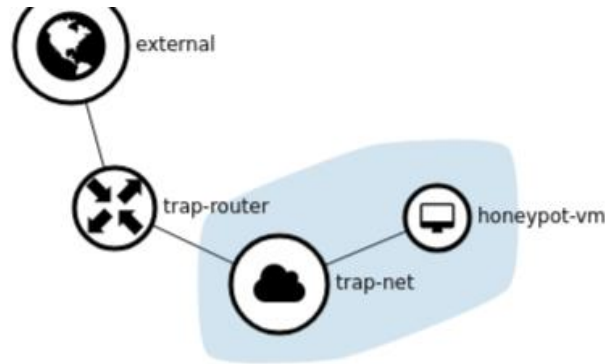
يعتمد التكامل بين المصيدة الأمنية وأداة تحليل إدارة الهوية والصلاحيات على ربط مخرجات كلّ منهما على مستوى الأحداث الأمنية (Security Events). توفر أداة IAM Analyzer معلومات بنوية تتعلق بهيكل الصلاحيات ومسارات التفويض المحتملة، في حين تسجّل المصيدة الأمنية الأنشطة السلوكية الناتجة عن تفاعل الحسابات مع الخدمات المعروضة.

يتم التعامل مع هذه البيانات ضمن سياق موحد يسمح بربط الصلاحيات الممنوحة للحسابات مع سلوكها الفعلي داخل البيئة السحابية، اعتماداً على عناصر مشتركة مثل الهوية والزمن. يساهم هذا الربط في التمييز بين المخاطر الناتجة عن سوء إعداد الصلاحيات فقط، وتلك التي تترافق مع سلوك مشبوه فعلي.

يوضح الشكل (3-5) البنية المعمارية لبيئة المصيدة الأمنية كما تم تنفيذها ضمن بيئة MicroStack. يتكوّن هذا الإعداد من خادم افتراضي مخصّص للمصيدة (honeypot-vm) يعمل ضمن شبكة افتراضية معزولة (trap-net)، ويتم ربطه بالعالم الخارجي عبر موجّه افتراضي مستقل (trap-router) يخضع لسياسات تحكّم محدّدة.

يعكس هذا التصميم مبدأ التعريض المقصود تحت السيطرة (Controlled Exposure)، إذ تبدو المصيدة من منظور خارجي كخدمة قابلة للوصول، في حين يتم احتواء جميع التفاعلات ضمن نطاق شبكي معزول يمنع أي تأثير على الخدمات التشغيلية الفعلية.

يوفّر هذا الإعداد بيئة آمنة لرصد السلوكيات المشبوهة وتسجيلها، مع الحفاظ على الفصل الكامل بين التحليل البنيوي للصلاحيات والتحليل السلوكي، مما يدعم تكامل المصيدة الأمنية كعنصر تجريبي ضمن النظام المقترح، ويُمهّد لإمكانية ربط مخرجاتها لاحقاً بنتائج تحليل الصلاحيات ضمن سياق أمني موحد.



الشكل 3-5 البنية الشبكية لبيئة المصيدة الأمنية ضمن MicroStack

الخاتمة

قدّم هذا الفصل وصفاً للحل المقترح من حيث التصميم والتنفيذ ضمن بيئة سحابية افتراضية (IaaS) بالاعتماد على MicroStack كنموذج عملي مبسّط لـ OpenStack. وتم توضيح البنية المعمارية التي تجمع بين أداة IAM Analyzer والمصيدة الأمنية Honeypot ضمن نفس الجهاز الافتراضي، مع الفصل المنطقي بينهما: إذ تعمل أداة التحليل كأداة Python مستقلة خارج المنصة وتتفاعل معها عبر واجهات OpenStack البرمجية، بينما تُنشر المصيدة كآلة افتراضية داخل المنصة ضمن شبكة معزولة.

كما استعرض الفصل مراحل عمل IAM Analyzer بدءاً من جمع البيانات وتطبيعها، مروراً ببناء الرسم البياني وتحليل الوصول، وصولاً إلى تطبيق القواعد الساكنة لإنتاج مؤشرات أمنية قابلة للتفسير والتتبع.

الفصل الرابع

النتائج

4 الفصل الرابع - النتائج

يهدف هذا الفصل إلى عرض وتحليل النتائج التجريبية الناتجة عن تطبيق النظام المقترح لتحليل إدارة الهوية والصلاحيات ضمن بيئة حوسبة سحابية من نمط البنية التحتية كخدمة (IaaS). تم التركيز في هذا الفصل على تقييم فعالية أداة IAM Analyzer في اكتشاف أنماط الضبط غير الآمن للصلاحيات، وتحليل الأثر البيئي لهذه الأنماط دون الاعتماد على أي بيانات تشغيلية أو سلوكية.

يعتمد التقييم على سيناريو تجريبي مضبوط (Controlled Experiment) تم تنفيذه ضمن بيئة MicroStack، بحيث يتم إدخال حالة تفويض مقصودة تمثل خطأ شائعاً في ضبط الصلاحيات، ومن ثم تحليلها باستخدام الأداة. يتيح هذا الأسلوب دراسة قدرة النظام على الكشف الاستباقي عن المخاطر البيئية المرتبطة بإدارة الهوية والصلاحيات في البيئات السحابية.

4.1 بنية مخرجات الأداة (Alert Structure)

ينتج النظام المقترح مخرجات التحليل على شكل مجموعة من التنبيهات الأمنية (Alerts)، يتم تمثيل كل منها ككائن مستقل يعكس حالة ضبط غير آمن محتملة ضمن بنية إدارة الهوية والصلاحيات. يعتمد هذا التمثيل على نموذج موحد يهدف إلى ضمان قابلية التفسير والتتبع، مع الحفاظ على الفصل بين توصيف الحالة ودليل اكتشافها.

يتكوّن كل تنبيه أمني من العناصر الأساسية التالية:

- تعريف القاعدة المفعّلة، والذي يحدّد القاعدة الساكنة المسؤولة عن توليد التنبيه ويتم ربطه بتصنيف أمني (Taxonomy) محدد.
- التصنيف الأمني، الذي يوضّح فئة الخلل المكتشف، مثل الصلاحيات المفرطة أو تعريض الواجهات الإدارية.
- الكيان المتأثر بالصلاحيات، ويشمل نوع الكيان (مستخدم بشري أو حساب خدمة)، الدور الممنوح، ونطاق الصلاحية (System / Project / Domain).
- دليل الاكتشاف البيئي (Evidence)، والذي يوضّح ما إذا كان التنبيه ناتجاً عن تعيين صلاحية مباشر، أو عن مسار وصول محدد، أو عن نمط وصول مجمّع يشمل عدة عمليات.
- مؤشرات توضيحية إضافية (Finding Hints) عند الحاجة، تُستخدم لتسليط الضوء على العمليات الحساسة التي تم الوصول إليها.

في الحالات التي تؤدي فيها نفس البنية التفويضية إلى إتاحة الوصول إلى عدة عمليات إدارية حساسة، يقوم النظام بتوليد أكثر من تنبيه باستخدام القاعدة الساكنة ذاتها. يتيح هذا الأسلوب تمثيلاً أدقّ لاتساع سطح الخطورة البيئي داخل نظام إدارة الهوية والصلاحيات، بدلاً من الاكتفاء بالإشارة إلى حالة فردية معزولة.

وتُستخدم المؤشرات الأمنية الناتجة عن هذا التحليل كأساس لدعم اتخاذ قرارات أمنية مدروسة، إذ توفر مخرجات قابلة للتتبع والتفسير، وتمكّن من فهم مصدر الخطورة وآلية نشوئها داخل بنية IAM، دون الحاجة إلى الاعتماد على أي بيانات تشغيلية أو سلوكية.

يوضّح الشكل (4-1) البنية العامة لمخرجات مرحلة القواعد الساكنة، حيث يعرض نموذجاً معمّماً لبنية التنبيه الأمني الناتج عن التحليل البنيوي لإدارة الهوية والصلاحيات. يبيّن هذا النموذج العناصر الأساسية التي يتكوّن منها كل تنبيه، بما يشمل معلومات القاعدة المفعّلة، الكيان المتأثر بالصلاحيات، ونوع الدليل البنيوي المستخدم في عملية الاكتشاف.

```
{
  "rule_id": "IAM.MISCONF.<TAXONOMY_ID>.<SEQUENCE>",
  "title": "<HUMAN_READABLE_TITLE>",
  "summary": "<ONE_LINE_SUMMARY_OF_THE_FINDING>",

  "category": {
    "class": "IAM Misconfiguration",
    "type": "<MISCONFIGURATION_TYPE>",
    "taxonomy_id": "<TAXONOMY_ID>"
  },

  "standard_refs": [
    {
      "standard": "<STANDARD_NAME>",
      "control": "<CONTROL_ID>"
    },
    {
      "standard": "<STANDARD_NAME>",
      "topic": "<STANDARD_TOPIC>"
    }
  ],

  "subject": {
    "principal_type": "<user | role | group | service>",
    "principal_name": "<PRINCIPAL_NAME>",
    "is_human": "<true | false>",
    "scope_kind": "<system | project | domain>",
    "scope_name": "<SCOPE_IDENTIFIER>",
    "role_name": "<ROLE_NAME>",
    "via_type": "<direct | group>"
  },

  "evidence": {
    "type": "<assignment_fact | reachability_path | reachability_aggregate>",
    "source": "<SOURCE_FILE_NAME>"
  }
}
```

الشكل 4-1 مخرجات مرحلة القواعد الساكنة

4.2 السيناريو التجريبي المعتمد

تم تصميم السيناريو التجريبي ليعكس نمطاً واقعياً وشائعاً من أخطاء الضبط في بيئات OpenStack، وبشكل خاص الأخطاء المرتبطة بمنح صلاحيات واسعة ضمن نظام إدارة الهوية والصلاحيات (IAM) دون قصد مباشر. يعتمد السيناريو على إنشاء مستخدم بشري غير إداري (Non-admin User)، ومنحه صلاحيات على مستوى النظام (System Scope) عبر دور افتراضي واسع الصلاحيات من نوع reader، وذلك من خلال الانتماء إلى مجموعة (Group Membership).

تم اختيار هذا السيناريو تحديداً لأن الأدوار من نوع reader أو member يُفترض أن تكون مقيدة بنطاقات أضيق مثل Project Scope أو Domain Scope، وليس على المستوى النظامي الشامل. وعليه، فإن هذا الإعداد يمثل حالة نموذجية لسوء ضبط قد لا يبدو خطيراً للوهلة الأولى، لكنه قد يؤدي إلى تأثير بنيوي واسع داخل نظام التفويض نتيجة تداخل الصلاحيات مع سياسات الوصول المعرفة على مستوى النظام.

يهدف هذا السيناريو إلى اختبار قدرة النظام المقترح على:

- اكتشاف الصلاحيات الواسعة الممنوحة لمستخدمين بشريين.
- تحليل مسارات الوصول غير المباشرة الناتجة عن سياسات التفويض.
- ربط النتائج بضوابط أمنية قياسية معترف بها.
- تقديم نتائج قابلة للتفسير دون الاعتماد على أي بيانات تشغيلية أو سلوكية.

4.3 تنفيذ السيناريو

بعد إنشاء المستخدم وتعيين الأدوار المطلوبة، تم تشغيل خط المعالجة (Pipeline) الكامل لأداة IAM Analyzer، والذي يشمل المراحل التالية:

- جمع بيانات إدارة الهوية والصلاحيات من خدمة Keystone.
- تطبيع البيانات وتحويلها إلى نموذج IAM موحد.
- بناء الرسم البياني البنيوي للعلاقات بين المستخدمين، الأدوار، والنطاقات.
- تنفيذ تحليل الوصول (Reachability Analysis) لاستخلاص العمليات الممكن الوصول إليها فعلياً.
- تطبيق مجموعة القواعد الساكنة (Static Rules) على نواتج التحليل البنيوي.

نتج عن هذه العملية مجموعة من المخرجات التحليلية (Snapshots) التي تمثل الحالة الفعلية للتفويض داخل النظام، وتشمل:

- تعيينات الصلاحيات الفعلية.
- الرسم البياني البنيوي لإدارة الهوية والصلاحيات.
- نماذج مسارات الوصول من الأدوار إلى العمليات.
- مخرجات القواعد الساكنة على شكل مؤشرات أمنية منظمّة (Security Indicators).

4.4 النتائج المكتشفة بواسطة القواعد الساكنة

أدى تطبيق القواعد الساكنة إلى توليد 24 تنبيهاً أمنياً، تعكس أنماط ضبط مختلفة ناتجة عن نفس خطأ التهيئة الأساسي. ويجدر التأكيد أن هذا العدد لا يشير إلى وجود 24 خطأ مستقلاً، بل إلى تعدد التأثيرات البنيوية الناتجة عن منح صلاحية واسعة واحدة على مستوى النظام.

يُظهر هذا السلوك كيف يمكن لإعداد واحد غير مضبوط بدقة أن ينتج عنه عدد كبير من مؤشرات الخطورة البنيوية داخل نظام IAM، نتيجة تفاعل الصلاحيات مع سياسات التفويض المعرفة عبر خدمات متعددة.

يمكن تصنيف أبرز النتائج المكتشفة ضمن الفئات التالية:

4.4.1 الصلاحيات المفرطة (T1 – Excessive Privilege)

تم رصد امتلاك مستخدم بشري دور reader على مستوى النظام، ما يمنحه قدرة واسعة على الاطلاع على موارد وخدمات متعددة داخل البيئة السحابية. يعكس هذا النمط خرقاً مباشراً لمبدأ أقل صلاحية (Least Privilege)، إذ إن أدوار القراءة ذات النطاق النظامي قد تؤدي إلى كشف معلومات بنيوية حساسة تتعلق بهيكل النظام، تكوين الخدمات، والعلاقات الداخلية بين المكونات.

4.4.2 الضعف الدلالي في سياسات التفويض (T4 – Policy Semantic Weakness)

أظهرت نتائج التحليل أن بعض العمليات المرتبطة بخدمة Keystone تعتمد في سياسات التفويض الخاصة بها على دلالات عامة مثل role:admin أو is_admin دون فرض قيود صريحة على النطاق. عند دمج هذه الدلالات مع أدوار ذات نطاق نظامي، قد يؤدي ذلك إلى توسع غير مقصود لسطح الوصول، حتى وإن لم يكن المستخدم مصنفًا كمسؤول إداري بشكل مباشر.

يمثل هذا النمط نقطة ضعف دلالية في تصميم السياسات، حيث تعتمد عملية التحكم بالوصول على توصيفات عامة للأدوار بدلاً من فرض قيود صريحة على النطاق السياقي للصلاحية.

4.4.3 تعريض الواجهات الإدارية (T9 – Admin Surface Exposure)

كشفت الأداة عن إمكانية وصول مستخدم غير إداري إلى عمليات تؤثر على كتالوج الخدمات ونقاط النهاية والخدمات المعرفة على مستوى النظام. لا يعني هذا النمط بالضرورة تنفيذ عملية ضارة فعلياً، لكنه يشير إلى تعريض واجهات إدارية حساسة لمستخدم لا يُفترض أن يمتلك هذا المستوى من الرؤية أو التأثير.

يمثل هذا النوع من النتائج مؤشراً بنيوياً على اتساع غير مبرر لسطح الإدارة (Administrative Surface)، وهو ما يتعارض مع ممارسات العزل الوظيفي الموصى بها في بيئات البنية التحتية السحابية.

4.4.4 الوصول إلى عمليات حساسة (X1 / X2)

أظهرت بعض النتائج إمكانية وصول المستخدم إلى عمليات تتعلق بإدارة السياسات الضمنية (Implied Roles) أو التحكم ببعض مكونات البنية التحتية مثل Host Aggregates ضمن خدمة Nova. يُعد هذا النوع من النتائج مؤشراً متقدماً على مخاطر تصعيد الصلاحيات أو التلاعب غير المباشر بسلوك النظام، حتى في حال عدم توفر صلاحيات إدارية صريحة.

تعكس هذه النتائج أهمية تحليل مسارات الوصول البنيوية، إذ قد تتيح بعض العمليات الحساسة تأثيراً غير مباشر على سلوك النظام أو توزيع الموارد.

4.4.5 تفسير النتائج وحدود التحليل

من المهم التأكيد على أن النتائج الناتجة لا تُصنّف كحوادث أمنية مؤكدة، وإنما كمؤشرات بنيوية تستدعي المراجعة والتحليل. تعتمد الأداة بشكل حصري على:

- الحالة الساكنة لإدارة الهوية والصلاحيات.
- نموذج التفويض الرسمي.
- سياسات التحكم بالوصول المعروفة في النظام.

ولا تعتمد الأداة على سجلات الدخول، أو تسلسل الأحداث الزمنية، أو السلوك الفعلي للمستخدمين أثناء التشغيل. وبذلك، فإن النتائج تعبّر عن ما هو ممكن بنيوياً ضمن نظام التفويض، وليس بالضرورة عمّا تم استغلاله فعلياً.

4.4.6 النتائج الإيجابية الكاذبة (False Positives)

نظراً لاعتماد الأداة على التحليل الساكن فقط، فمن الممكن أن تنتج بعض النتائج الإيجابية الكاذبة (False Positives)، وذلك لأسباب منهجية معروفة في هذا النوع من التحليل، من أبرزها:

- غياب السياق التشغيلي: قد تكون بعض الصلاحيات الواسعة مبررة وظيفياً في سياق معين (مثل مهام المراقبة أو التدقيق)، إلا أن هذا السياق لا يمكن استنتاجه من نموذج IAM وحده.
 - تحليل بنيوي محافظ (Conservative Analysis): تم تصميم القواعد بأسلوب محافظ (-Fail-safe)، بحيث تفضّل الإبلاغ عن نمط محتمل الخطورة على تجاهله، حتى لو لم يُستغل فعلياً.
 - عدم دمج البيانات السلوكية: عدم توفر بيانات سلوكية أو زمنية يمنع التمييز بين صلاحية غير مستخدمة وصلاحية مستغلة فعلياً.
- تم تصميم النظام المقترح ليكون قابلاً للتوسّع، حيث يمكن مستقبلاً تقليل معدلات النتائج الإيجابية الكاذبة من خلال:

- دمج التحليل الساكن مع:
 - تحليل سلوكي (Behavioral Analysis).
 - بيانات زمنية (Temporal Correlation).
- ربط النتائج مع أنظمة SIEM عند توفرها.
- استخدام تقنيات تعلم الآلة (Machine Learning) لتصنيف النتائج اعتماداً على:
 - أنماط الاستخدام الفعلي.
 - تاريخ التفاعل مع الصلاحيات.

- تكرار وتزامن الأحداث.

وبذلك، تُستخدم القواعد الساكنة كطبقة أولى دقيقة وقابلة للتفسير، يتم تعزيزها لاحقاً بطبقات تحليل أكثر تعقيداً.

الخاتمة

تُظهر النتائج التجريبية أن النظام المقترح قادر على كشف أنماط ضبط غير آمن للصلاحيات وتحليل أثرها البنوي بصورة شاملة، وربط هذه الأنماط بضوابط أمنية قياسية معترف بها، دون الحاجة إلى بيانات تشغيلية. كما تؤكد النتائج أن خطأ ضبط واحد قد يؤدي إلى سلسلة واسعة من التأثيرات داخل نظام التفويض، وهو ما يصعب اكتشافه باستخدام المراجعة اليدوية التقليدية.

وبذلك، يثبت هذا الفصل أن التحليل الساكن يمثل أساساً قوياً للتحليل الاستباقي في بيئات IaaS، ويمهد لإمكانية تطوير النظام مستقبلاً نحو تحليل أمني أكثر شمولية عند دمج مع آليات رصد سلوكي متقدمة.

الخاتمة

يُمثل هذا المشروع تطبيقاً عملياً لمنهجية تحليل أمني تستهدف دراسة بنية إدارة الهوية والصلاحيات في البيئات السحابية، مع التركيز على الكشف المبكر عن أنماط الضبط غير الآمن للصلاحيات ضمن سياق البنية التحتية كخدمة (IaaS). وقد تم تحقيق ذلك من خلال تطوير أداة Cloud IAM Analyzer تعتمد على التحليل الساكن لسياسات التفويض، بدءاً من جمع البيانات، مروراً بتطبيعها وبناء نموذج بنيوي قائم على الرسوم البيانية، وصولاً إلى تطبيق قواعد ساكنة قابلة للتفسير.

اعتمد المشروع على بيئة اختبار قائمة على MicroStack لمحاكاة بيئة OpenStack واقعية، مما أتاح تحليل نموذج التفويض كما هو مطبق فعلياً، دون الاعتماد على افتراضات نظرية أو بيانات تشغيلية. وأظهر التطبيق العملي أن تحليل بنية الصلاحيات وحدها كافٍ لاكتشاف حالات صلاحيات مفرطة، ومسارات وصول غير مباشرة، وأنماط تفويض قد تشكل مخاطر أمنية محتملة، حتى في غياب أي نشاط هجومي فعلي.

كما تضمن النظام إنشاء مصيدة أمنية (HoneyPot) ضمن بيئة معزولة، صُممت كعنصر تجريبي داعم للبنية العامة للنظام، بهدف توفير نقطة تفاعل خاضعة للمراقبة يمكن الاستفادة منها مستقبلاً في ربط التحليل البنيوي بالسلوك العملي. وقد تم في هذا المشروع التركيز على إعداد المصيدة من الناحية المعمارية دون إدخالها في مرحلة استغلال أو ترابط تشغيلي مع منظومات تحليل أخرى.

أظهرت نتائج التحليل أن الاعتماد على التحليل الساكن قد يؤدي في بعض الحالات إلى ظهور مؤشرات تحتاج إلى مراجعة بشرية، وهو ما يُعد سمة معروفة لهذا النوع من التحليل. إلا أن هذا القيد تم التعامل معه من خلال تصميم قواعد تحليل محافظة وقابلة للتفسير، تفضّل التنبيه المبكر على إغفال المخاطر المحتملة، مع الحفاظ على وضوح مصدر كل نتيجة ومسار الوصول المؤدي إليها.

وبذلك، يقدّم هذا المشروع إطاراً منهجياً واضحاً لتحليل إدارة الهوية والصلاحيات في بيئات IaaS، ويمهّد لتطويرات مستقبلية للنظام يمكن البناء عليها عبر توسيع نطاق القواعد، أو دمج طبقات تحليل إضافية عند توفر البيانات التشغيلية والبنية الداعمة، بما يعزّز دقة التحليل وشموليته دون المساس بقبليته للتفسير.

- [1] Mell, P., & Grance, T. (2011). *The NIST Definition of Cloud Computing* (NIST SP 800-145). National Institute of Standards and Technology.
- [2] Zhang, Q., Cheng, L., & Boutaba, R. (2010). *Cloud computing: State-of-the-art and research challenges*. *Journal of Internet Services and Applications*, 1(1), 7–18.
- [3] Sharma, S., Gupta, G., & Laxmi, P. R. (2014). *A survey on cloud security issues and techniques*. *arXiv*.
- [4] Gholami, A., & Laure, E. (2016). Security and privacy of sensitive data in cloud computing: A survey of recent developments. *arXiv*
- [5] Hashizume, K., Rosado, D. G., Fernández-Medina, E., & Fernandez, E. B. (2013). An analysis of security issues for cloud computing. *Journal of Internet Services and Applications*, 4(1), 5.
- [6] Chappell, D. (2010). *Introducing Windows Azure*. Microsoft Press.
- [7] Catteddu, D., & Hogben, G. (2009). *Cloud computing: benefits, risks and recommendations for information security*. European Network and Information Security Agency (ENISA).
- [8] Jain, P. (2025). Identity and access management in the cloud. *International Journal of Scientific Research in Computer Science, Engineering and Information Technology*, 11(2), 1528–1535.
- [9] Spitzner, L. (2003). *Honeypots: Tracking Hackers*. Addison-Wesley.
- [10] Mokube, I., & Adams, M. (2007). Honeypots: Concepts, Approaches, and Challenges. *Proceedings of the 45th Annual Southeast Regional Conference*, 321–326.
- [11] Zuech, R., Khoshgoftaar, T. M., & Wald, R. (2015). Intrusion detection and Big Heterogeneous Data: a Survey. *Journal of Big Data*, 2(1), 3
- [12] Cloud Security Alliance. (2025). Top threats to cloud computing: Deep dive 2025. Cloud Security Alliance.
- [13] Microsoft Corporation. (2024). State of multicloud security report 2024. Microsoft .

- [14] Esther, D., Jonathan, G., et al. (2025). Cloud identity and access management (IAM) automation. ResearchGate .
- [15] Fixing privilege escalations in cloud access control with MaxSAT and graph neural networks. Proceedings of an international conference on cloud security and access control.
- [16] Pitkar, A. (2025). Cloud security automation through symmetry: Threat detection and response. Journal of Cloud Security Automation.
- [17] Valiyev, A. (2025). Cyber threat detection with honeypots. International Journal of Cybersecurity and Threat Intelligence.
- [18] Morić, Z., Dakić, V., & Regvart, D. (2025). Advancing cybersecurity with honeypots and deception strategies. Informatics, 12(1), Article 14 .
- [19] SkyEye: When your vision reaches beyond IAM boundary scope in AWS cloud. Proceedings of an international conference on cloud security.
- [20] Aljuneidi, M. (2025). Dynamic honeypot deployment for enhanced cybersecurity. Journal of Advanced Cyber Defense Systems.
- [21] Center for Internet Security. (2024). CIS benchmarks: Enhancing security configurations in multi-cloud infrastructures.

